

G-Data Integration Profile – Combined Credential and Platform bound Enforcement (CCPE-H)

Abstract

CCPE-H (G-Data) is the data-authorisation profile of the GAuth framework. It lets an autonomous agent read, derive from, transform, and emit data assets on a principal's behalf under a signed delegation credential, while the data platform's own access-governance still applies.

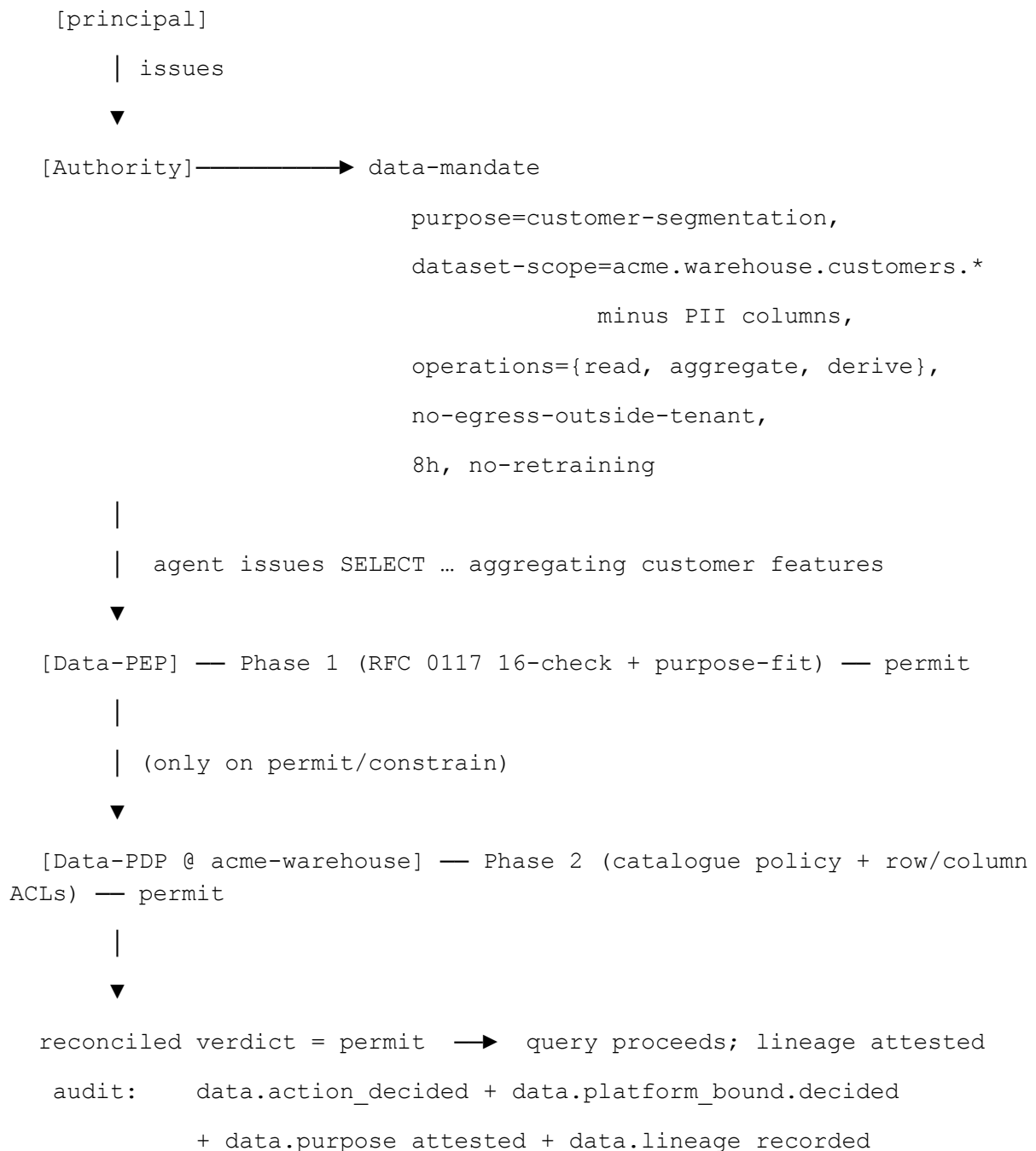
The profile defines:

- a Data-Mandate envelope (§3.1) — a Power-of-Attorney credential per RFC 0115 specialised for data;
- a purpose-bound decision surface — purpose → dataset-scope → operation — with purpose-fit as a pre-action invariant and behavioural-conformance as an in-action / post-action invariant;
- a bipolar enforcement chain — Power-PEP (credential-bound, Phase 1) followed by Data-PDP (platform-bound, Phase 2), reconciled by more-restrictive-wins;
- engine-neutral cookbook bodies for nine data-platform substrates across three families: enterprise data-governance catalogues (Collibra, Atlan, Informatica, IBM watsonx.data / Cloud Pak for Data, Microsoft Purview); access-governance overlays (Immuta as canonical, Privacera as alternative); platform-native catalogues (Databricks Unity Catalog, Snowflake Horizon, AWS Lake Formation / Glue Data Catalog);
- the CCPE-H-NCI / NCP / NCO non-conformant-variant taxonomy (§4.6);
- the S1 / S2 / S3 deployment-scenario architecture (§2.6) where only S2 is conformant to G-Data;
- the §13.A GAuth Open-Core Reference Connector Slot Registry foundation, naming the multi-instance `data\_pdp` slot (Type-A) and the single-instance `data\_authority` slot (Type-B), the tariff-tier matrix, and the open-core symmetry rules;
- the §6.5a per-call metering rules for `recordDataDecision()` and `recordLineageAttestation()`;

- the §15 IANA-style reservations for tariff-tier / slot-type / `phase2\_evaluation.profile` values; and
- Appendix A - the formal NIST AI RMF v1.0 MAP-function cross-walk against the CCPE-H normative surface.

How CCPE-H Works in 60 Seconds (Informative)

A worked example: a market-research agent prepares a quarterly customer-segment summary on behalf of its principal at data platform acme-warehouse.



Three things that make this profile distinct from a "the warehouse already has row-level security" flow:

- Purpose-bound mandate. The mandate names the purpose under which the agent is delegated, not just the dataset. A query that is row/column-permitted by the platform but purpose-misfit (e.g. an aggregation mandate used to extract per-row PII) is denied at Phase 1 even where Phase 2 would permit.
- Two-stage enforcement. The Power-PEP enforces what the principal delegated (purpose, scope, operations, retention, retraining-prohibition, egress-boundary); the Data-PDP enforces what the platform allows (row/column ACLs, masking policies, dataset classification). The stricter of the two wins. A Phase-1 deny short-circuits Phase 2.
- Lineage attestation as in-action evidence. Every permitted action emits a `data.lineage_recorded` audit event binding the action's input-dataset references, the operation class, and the output-artefact reference into the trace. Behavioural conformance is then auditable post-hoc: a downstream reviewer can verify that the derived artefact's content stays inside the purpose envelope.

If the Data-PDP doesn't answer within `phase2_timeout_ms`, the mandate's `fail_disposition` decides: `fail_closed` denies; `fail_drop_egress_only` denies egress-class operations but lets read-only / in-platform operations through if Phase 1 already permitted.

Status of This Memo

This is a Gimel Foundation Standards Track document.

This document is a product of the Gimel Foundation (GiFo). It represents the current consensus of the Gimel Foundation community. It has performed review and has been approved for publication.

Information about the status of this document, any errata, and how to provide feedback on it may be obtained at <https://gimelfoundation.com> or <https://github.com/Gimel-Foundation>.

Legal Notice

Copyright © 2026 Gimel Foundation and the persons identified as the document authors. This document is licensed under Apache License 2.0 per GiFo-RFC 0090 and Legal Terms of Gimel Foundation; see the GiFo Legal Provisions for the grant and any reservations.

This document is subject to the Gimel Foundation's Legal Provisions Relating to GiFo Documents (see <http://GimelFoundation.com> or <https://github.com/Gimel-Foundation>) in effect on the date of publication of this document. Please review these documents carefully, as they describe your rights and restrictions with respect to this document. Code Components extracted from this document must include License text as described in Section 4 of the GiFo Legal Provisions Relating to GiFo Documents.

The distinguished GAuth standard is protected by copyright. Patent for GAuth is pending (PCT). GAuth licensing is not covering the following Exclusions, which are subject to separate license conditions and are also protected by copy right as well as pending patent:

- AI-enabled Governance,
- Web3-Integration,
- DNA-based Identity and PQC associated.

These domains are excluded from the open-source GAuth specification and are governed by separate Gimel Technologies commercial licenses.

GAuth is an open-source standard and can be based on OAuth, OpenID Connect and MCP. Copyrights and licenses of the GAuth building blocks apply accordingly.

GAuth is a registered trademark of the Gimel Foundation. Collibra is a trademark of Collibra NV; Atlan is a trademark of Atlan Pte. Ltd.; Informatica, MDM, EDC, and CLAIRE are trademarks of Informatica LLC; IBM, watsonx.data, and Cloud Pak for Data are trademarks of International Business Machines Corporation; Microsoft and Microsoft Purview are trademarks of the Microsoft Corporation; Immuta is a trademark of Immuta, Inc.; Privacera is a trademark of Privacera, Inc.; Databricks and Unity Catalog are trademarks of Databricks, Inc.; Snowflake and Horizon are trademarks of Snowflake Inc.; AWS, Lake Formation, and Glue are trademarks of Amazon.com, Inc.; NIST and the NIST AI Risk Management Framework are products of the U.S. National Institute of Standards and Technology referenced descriptively under nominative fair use. All cited platforms are referenced descriptively as exemplar data-platform substrates; no endorsement, sponsorship, partnership, or affiliation is implied.

This document is published under Apache License 2.0 per GiFo-RFC 0090 and the other Legal Terms of Gimel Foundation.

Notational Conventions

The key words **Must**, **Must Not**, **Required**, **Shall**, **Shall Not**, **Should**, **Should Not**, **Recommended**, **Not Recommended**, **May**, and **Optional** in this document are to be interpreted as described in BCP 14 (RFC 2119, RFC 8174) when, and only when, they appear in bold capitalised form.

The term CCPE-H designates the H-profile of the CCPE family per the title of this document.

The term mandate denotes a Data-Mandate per §3.1 unless qualified otherwise. Data-PEP denotes the Data-Profile Policy Enforcement Point per §3.3. Data-PDP denotes the platform-bound Phase 2 evaluator per §2.5.b. Power-PEP denotes the credential-bound Phase 1 evaluator per RFC 0117. Authority denotes the mandate-issuance and lifecycle service per §2.4.b.

Note on terminology — Power*Point vs. Policy*Point. GiFo-RFCs 0110 and 0111 normatively define P*P in the GAuth context as Power Decision / Enforcement / Administration / Information / Verification Point, emphasising that GAuth governs delegated authority (power), not platform-configured policy. RFC 0150 uses the prefixed forms (Power-PEP, Policy-PDP); RFC 0160 uses (Power-PEP, Comm-PDP); RFC 0180 uses (Power-PEP, Code-PDP); RFC 0420 uses (Power-PEP, Device-PDP); RFC 0170 uses (Power-PEP, Commerce-PDP); RFC 0210 uses (Power-PEP, Identity-PEP). This RFC follows the same convention: Data-PDP designates the platform-bound Phase-2 evaluator on the data-platform axis (the eighth axis in the CCPE family). Where this document uses the unqualified term PEP without a prefix, the prefix is determined by context.

Note on terminology — "Purpose". This RFC uses purpose as a normative term-of-art for the principal-stated processing intention under which a data action is delegated (e.g. customer-segmentation, fraud-investigation, model-training-prohibited). The term aligns with the GDPR / EU AI Act notion of purpose limitation and with the NIST AI RMF MAP function notion of intended use context. It is deliberately distinct from RFC 0210's identity-bound semantics and from RFC 0170's mandate-class enum.

Table of Content

1. Scope
2. Domain Architecture
3. Data-Mandate Envelope and Decision Surface
4. Engine-Neutral Architecture and Conformance
5. Concept Mapping — GAuth/CCPE ↔ Data-Platform Substrates (Informative)
6. Cryptographic Requirements
7. Cookbook Bodies (Informative)
8. References
9. Conformance Levels and Reservations (Normative)
10. CCPE Family Lineage (Informative)
11. NIST Cross-Walk — AI RMF MAP Function (Informative)
12. Acknowledgements
13. Open Issues
14. IANA / Registry Reservations (Normative)

Appendix

NIST AI RMF v1.0 — MAP Function Cross-Walk to CCPE-H

* * *

1. Scope

1.1 What This RFC Does

- a) Defines CCPE-H (G-Data), the integration profile of the GAuth Authorization Framework (RFC 0111) for the agent-to-data-platform authorisation domain, addressing two gaps that existing platform-bound data governance does not close on its own:
- b) Purpose-fit verification (pre-action). Existing data-governance catalogues and access-governance overlays answer "may this principal access this asset?". They do not answer "is this specific dataset appropriate for this authorised request, given the purpose under which the agent was delegated?". CCPE-H Phase 1 supplies that check against the Data-Mandate's purpose field.
- c) Behavioural conformance (in-action / post-action). Existing platforms log access events; they do not bind those events to a principal-stated purpose envelope and a downstream lineage attestation. CCPE-H §3.4 / §3.5 supply the audit-event schema and the lineage-attestation event needed for downstream reviewers to verify that the agent's data processing stayed within the delegated purpose.
- d) Specifies the Data-Mandate envelope (§3.1) - a Power-of-Attorney credential per RFC 0115 specialised for the purpose / dataset-scope / operation phase classes, with phase-class binding, parent-mandate chain, parent-chain freshness bounds, and a forward-compatibility envelope.
- e) Specifies the Data Power-of-Attorney (Data-PoA) lifecycle aggregation (§3.2) and the cascade-revocation invariants.
- f) Specifies the Data-PEP and the Decision Envelope (§3.3) under the unified three-value verdict vocabulary {permit, deny, constrain} plus a separate obligations array.
- g) Specifies the Data Audit Trail (§3.4) and the persistence-before-stream invariant; specifies the lineage-attestation event (§3.5).
- h) Specifies the engine-neutral architecture and conformance bar (§4) and the per-platform cookbook bodies (§7).
- i) Specifies the non-conformant variant taxonomy CCPE-H-NCI / NCP / NCO (§4.6).
- j) Specifies the cryptographic baseline (§6.1–§6.9), including the §6.2 canonicalisation and §6.3 transport anchors.
- k) Specifies the consolidated security considerations (§6.10), with cascade discipline at §3.2 and lineage-attestation discipline at §3.5.
- l) Reserves the §9.1 Reservations Catalogue, including the verdict/obligation identifier `ccpe_h_purpose_binding`.
- m) Provides the §11 cross-walk to NIST AI RMF MAP function as the natural standards anchor for purpose-fit verification, with the formal sub-category mapping table at Appendix A.
- n) Provides full informative cookbook bodies for nine data-platform substrates (§7.1–§7.9): concrete Phase-2 integration surface, projection rules from Data-

Mandate fields onto substrate primitives, reconciliation rule across the substrate's internal multi-engine surfaces, and §3.5 lineage source per substrate.

- o) Specifies the §13.A GAuth Open-Core Reference Connector Slot Registry foundation for the data-axis slots and the §6.5a per-call metering rules realising open-core symmetry against those slots.

1.2 What This RFC Does Not Do

This RFC does not:

- a) Modify, supersede, or characterise any third-party data-governance, data-catalogue, or access-governance specification beyond the scope and register of the citations explicitly stated at §7 and §8.
- b) Specify any deployment-time or runtime obligation that an implementation of a third-party data-governance specification adopt CCPE-H.
- c) Specify any storage-engine, query-planner, columnar-format, or transactional-isolation semantics; CCPE-H operates at the authorisation-decision and lineage-attestation register only.
- d) Specify any model-training pipeline obligations beyond the right of a Data-Mandate to carry a no_retraining constraint and the obligation of the Data-PEP / Data-PDP to honour it.
- e) Specify any data-quality, data-residency-jurisdiction, or schema-evolution semantics; those remain platform-side concerns surfaced (where present) into the Phase-2 verdict's obligations array.
- f) Specify any ITSM / GRC workflow surface; service-desk and change-management tooling sit outside the data-runtime axis and are not addressed by CCPE-H.
- g) Constitute any election against, waiver of, or pre-condition to any specific intellectual-property remedy.
- h) Evaluate vendors and/or solution-providers.

1.3 Relationship to Adjacent Specifications

The CCPE-H architectural surface depends only on the GAuth credential-layer baseline:

- GiFo-RFC 0110 — GAuth Protocol Engine. Authority, Power-PAP per RFC 0110 §4.
- GiFo-RFC 0111 — GAuth Authorization Framework. CCPE-H is an integration profile of RFC 0111.
- GiFo-RFC 0115 — Power-of-Attorney Credential Definition. Data-Mandate is a specialisation of the RFC 0115 envelope; signature-algorithm baseline anchored to RFC 0115 §5.4.
- GiFo-RFC 0116 — Extended Token / W3C VC Representation. Optional VC-form mandate carriage.

- GiFo-RFC 0117 — GAuth PEP Interface. Power-PEP at Phase 1 implements the RFC 0117 16-check pipeline; verdict vocabulary aligned with RFC 0117 §4.
- GiFo-RFC 0118 — GAuth Management API. Authority issuance / revocation / introspection surface.
- GiFo-RFC 0125 SDK v0.93+ — GAuth Open-Core SDK; slot-registry implementation discipline for §13.A.
- GiFo-RFC 0140 v1.2 — `phase2\_evaluation.profile` partitioning-key origin.
- GiFo-RFC 0160 — G-Audit Profile. Audit-event payload baseline for the §3.4 / §3.5 streams.

The architectural-pattern lineage of CCPE-H (three-service Console / Authority / Data- Runtime pattern; bipolar credential-bound + platform-bound enforcement; mandate envelope shape; non-conformant-variant taxonomy convention) is shared across the CCPE family. No sibling profile is a normative dependency of this RFC. Three sibling profiles are cited informatively for boundary-line clarification at §1.4:

- GiFo-RFC 0150 (CCPE-B / G-PaC). Standalone Policy-as-Code engine integration; informative cross-reference for the §13.A.7 dual-path Data-PDP architecture (PEP Phase-2 extension point precedent at RFC 0150 §4.3.A). CCPE-H may, optionally, carry a Phase-2 verdict that has itself been produced by a downstream PaC engine; in that case the PaC engine is the deployment's choice of Data-PDP back-end, but the integration surface seen by the Power-PEP is the CCPE-H §4 contract, not the CCPE-B contract directly.
- GiFo-RFC 0170 v0.9.1 (CCPE-F / G-Commerce). Structural-symmetry reference for the front matter, §2 architecture, §3 envelope, §6 cryptographic baseline, and the §13.A-equivalent slot-registry foundation against `commerce\_pdp` / `commerce\_authority`.
- GiFo-RFC 0210 v0.7 (CCPE-G / G-IBE). Identity-bound IAM platform integration; structural-symmetry reference for the §1.4 boundary register, §1.5 normative-exclusion shape, the catalogue-and-prescribe posture, and the §13.A foundation against `identity\_platform` / `identity\_bridge`. CCPE-G provides the identity under which the data action is taken; CCPE-H provides the purpose-bound authorisation over the data action itself. The two profiles compose: an identity-bound deployment that also operates a CCPE-H Data-PEP gets CCPE-G + CCPE-H conformance; an identity-bound deployment that does not is a §4.6 CCPE-H-NCI variant on the data axis.

External non-Foundation framing references: IETF RFC 2753 (Framework for Policy-based Admission Control — origin of the PDP/PEP split this profile inherits) and NIST SP 800-207 (Zero Trust Architecture — origin of the per-action authorisation discipline). NIST AI RMF v1.0 is the natural cross-walk anchor for the purpose-fit dimension and is treated at §11 (in-body summary) plus Appendix A (formal sub-category cross-walk).

The §13.A foundation specified herein is realised in the GAuth Open-Core SDK at future versions and in the Gimel Foundation reference operator (Gimel Auth) at the corresponding release. This version normatively names the slot-registry contract; SDK-side implementation discipline is documented in the RFC 0125 SDK repository and in the descriptive companion document ``docs/CONNECTOR_SLOT_FOUNDATION.md`` (open-core foundation contract spanning all 13 slots).

1.4 Boundary Lines vs. Adjacent Profiles

This subsection is the normative boundary register that disambiguates CCPE-H from neighbouring CCPE profiles and from existing data-governance platforms. The catalogue-and-prescribe posture established by RFC 0210 §3.4 applies: the boundary lines are descriptive of architectural shape, not pejorative of the neighbouring profile or platform.

- a) **CCPE-H vs. existing data-governance catalogues** (Collibra / Atlan / Informatica / IBM watsonx.data / Microsoft Purview / Databricks Unity Catalog / Snowflake Horizon / AWS Lake Formation). Existing catalogues are platform-bound and access-oriented: they answer "who may access which assets, under which classification, with which masking?". They do not answer the credential-bound questions "is this specific dataset appropriate for this authorised request?" (purpose-fit, pre-action) and "is the agent's processing of this data consistent with the purpose under which it was delegated?" (behavioural conformance, in-action / post-action). CCPE-H Phase 1 supplies both questions; the catalogue's Phase 2 continues to supply its existing answers unchanged.
- b) **CCPE-H vs. access-governance overlays** (Immuta / Privacera). Access-governance overlays sit between the principal's identity and the platform's row/column-level enforcement and attach attribute-based policy. They answer "given who the requester is, which rows and columns should be visible?". They do not answer "is the purpose under which the request was delegated consistent with the dataset's stated allowable purposes?". CCPE-H Phase 1 supplies the purpose check; the overlay's row/column / masking decision continues to be the deployment's Phase-2 implementation choice.
- c) **CCPE-H vs. CCPE-B** (G-PaC). CCPE-B specifies how a standalone Policy-as-Code engine (OPA / Cedar / equivalent) becomes the Phase-2 evaluator for the deployment. CCPE-H is a data-platform-axis profile: a CCPE-H deployment may use a PaC engine as its Phase-2 implementation, but the contract seen by the Power-PEP is the CCPE-H §4 data-platform contract. PaC is the engine; G-Data is the data-axis profile that may choose PaC as one of its Phase-2 back-ends.

- d) **CCPE-H vs. CCPE-G (G-IBE).** CCPE-G binds the agent's authority to its identity object in an IAM platform. CCPE-H binds the agent's authority to a purpose-stated, dataset-scoped Data-Mandate over a data-platform substrate. The two profiles are orthogonal: the identity is who, the data-mandate is what under which purpose. A deployment may operate either profile alone; conformant operation of both is the recommended posture for any deployment whose agents act on identity-issued credentials and read or transform data.
- e) **CCPE-H vs. ITSM / GRC workflow tooling.** Workflow tooling (incident management, change-approval, control-evidence collection) is operationally adjacent to data governance but is not a data-runtime axis. CCPE-H does not specify any ITSM / GRC integration; if a future RFC covers that surface it will be a separate workflow / ITSM profile, not a section of CCPE-H.

1.5 Normative Technology Exclusions

The following CCPE-H-specific territories are out-of-scope:

- a. Storage-engine internals (file formats, columnar layouts, indexing, buffer-pool semantics) — out of scope.
- b. Query-planner, query-optimiser, and cost-model internals — out of scope.
- c. Data-quality scoring and data-quality-rule engines — out of scope.
- d. Schema-evolution / migration tooling internals — out of scope.
- e. Data-residency jurisdictional analysis — surfaced (where the platform expresses it) into the Phase-2 verdict's obligations array, but its computation is platform-side.
- f. Model-training pipeline internals beyond honouring a no_retraining constraint on a permitted action.

1.6 No-Waiver Disclaimer

The technical descriptions and concept-mappings contained in this document serve solely the purpose of architectural comparability between specifications. They do not constitute recognition of the legal effectiveness, originality, or completeness of the referenced third-party specifications. Existing rights, claims, and defences - including, but not limited to, patent rights and the licence terms set forth in GiFo-RFC 0090 - remain unaffected by this document.

In particular, and without limiting the generality of the foregoing:

- a) No estoppel by silence. Descriptive citation does not constitute the Gimel Foundation's, any contributor's, or any member's acquiescence in, consent to, validation of, or waiver of any objection to that third-party material.
- b) No grant by description. No licence is granted by this document to any patent right, copyright (beyond the Apache 2.0 grant covering this document's own text), trade-secret right, or other intellectual-property right.
- c) No characterisation beyond the stated comparison.
- d) No election against remedies. The Gimel Foundation reserves all rights and remedies in respect of its intellectual-property portfolio.

This §1.6 is the normative anchor for the No-Waiver framing.

2. Domain Architecture

2.1 The Data-Authorisation Domain

The data-authorisation domain comprises three sequential phase classes:

- a) **Purpose phase.** The principal delegates a purpose-stated mandate — for example, "perform customer-segmentation aggregation over the customers dataset, no PII columns, no model training, no egress outside tenant, 8h".
- b) **Dataset-scope phase.** The agent has resolved the mandate's dataset-scope expression to a concrete dataset reference (table, view, file, stream, model artefact).
- c) **Operation phase.** The agent presents a concrete operation (read, aggregate, derive, write, egress, train) against the resolved dataset reference.

The three phases are sequential and order-preserving: an operation-phase decision Must Not be evaluated before its corresponding dataset-scope-phase decision; a dataset-scope-phase decision Must Not be evaluated before its corresponding purpose-phase decision.

2.2 Bipolarity: Platform-Bound Flow and Credential-Bound Flow

- a) **Platform-Bound Flow.** The decision is evaluated by a data-platform service (catalogue, access-governance overlay, or platform-native row/column engine). Authoritative source: data-platform operator. Bound artefact: catalogue-side or platform-side configuration.
- b) **Credential-Bound Flow.** The decision is evaluated by a credential layer that verifies a signed delegation credential issued by the principal. Authoritative source: principal. Bound artefact: Power-of-Attorney credential per RFC 0115.

A conformant CCPE-H deployment Must operate both flows in chain: the credential-bound flow produces the Phase 1 verdict (Power-PEP + purpose-fit check); the platform-bound flow produces the Phase 2 verdict (Data-PDP). The two verdicts are reconciled per §2.5 such that the more restrictive of the two is the final decision.

The bipolarity is the central architectural feature of CCPE-H. Phase 1's distinctive contribution is the purpose dimension; Phase 2's distinctive contribution is the platform-side row/column/classification dimension; neither subsumes the other.

2.3 Architectural Deltas

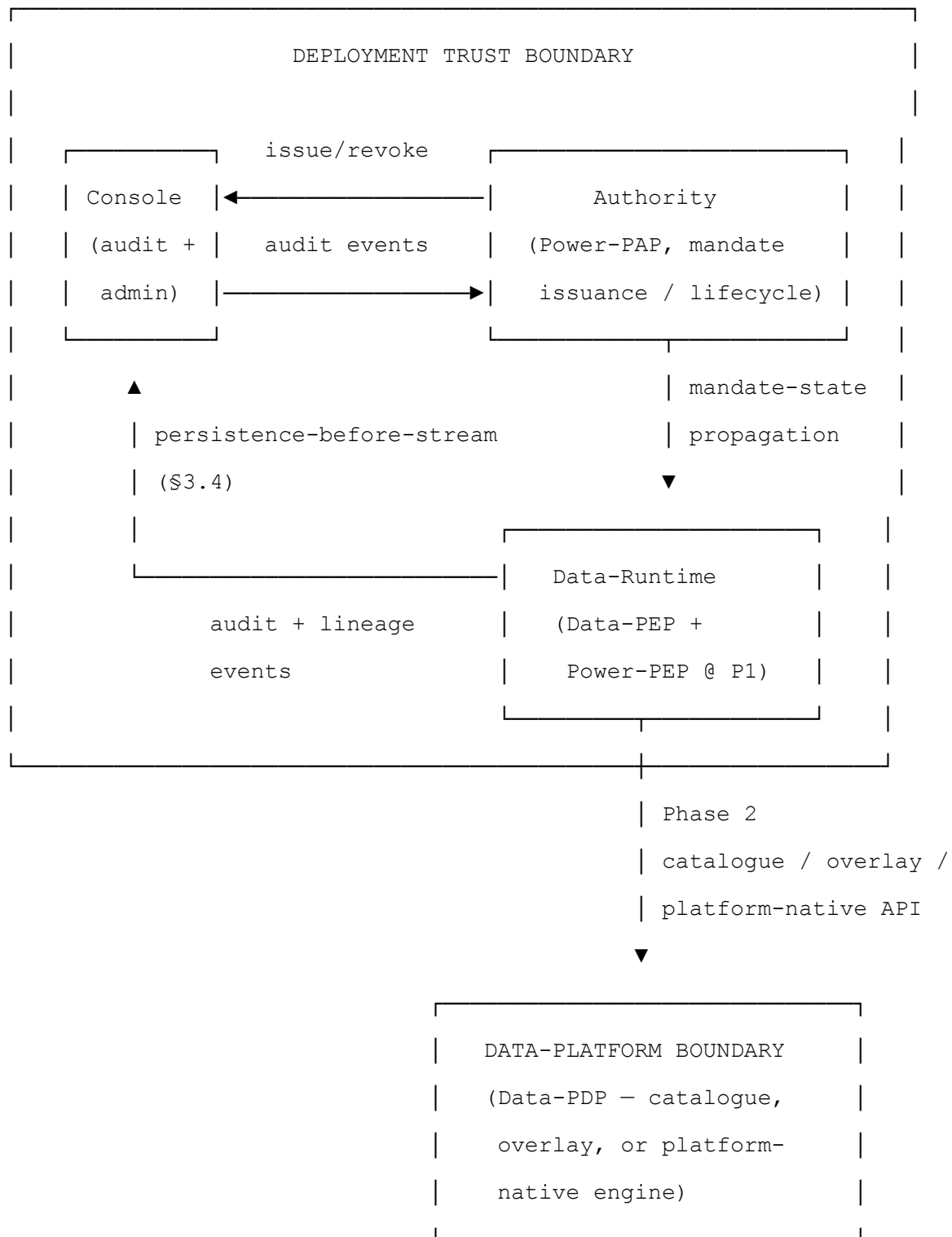
- a) **Purpose-fit asymmetry.** The platform-bound flow does not see the principal's purpose; only Phase 1 can.
- b) **Three-phase decision surface.** Purpose / dataset-scope / operation. Unique to the data domain.
- c) **Lineage-attestation obligation.** The data domain uniquely requires post-hoc verifiability of behavioural conformance; §3.5 specifies the lineage-attestation event.
- d) **Counterparty asymmetry on cookbook scope.** The Data-PDP is operated by a platform whose API surface the deployment uses but whose internals it does not control; §7 cookbooks are necessarily descriptive of the platform's published surface.

2.4 Three-Service Pattern

A conformant CCPE-H deployment comprises three logically-distinct services. Conflation of any two roles into a single service is non-conformant.

- a) **Console.** Operator-facing surface. Hosts the audit-trail event store, mandate registry, governance-profile administration surface, and operator-facing dashboards.
- b) **Authority.** Mandate-issuance and lifecycle service. Hosts the Power-PAP (per RFC 0110 §4), issuance pipeline, mandate-revocation pipeline, and mandate-state propagation pipeline.
- c) **Data-Runtime.** Action-time enforcement service hosting the Data-PEP and the Power-PEP at Phase 1. Carries the §3.5 lineage-attestation emitter.

Trust-boundary diagram (informative):



Conflations to avoid: Console $\rightleftharpoons$ Authority (operator can read-write its own audit trail); Authority $\rightleftharpoons$ Data-Runtime (issuer can self-validate without independent enforcement); Console $\rightleftharpoons$ Data-Runtime (audit consumer can rewrite its own decisions).

2.5 The Power-PEP → Data-PDP Chain

- a) Phase 1 — Credential-bound enforcement. Power-PEP runs the 16-check pipeline of RFC 0117 against the active Data-Mandate. In addition to the RFC 0117 checks, the Power-PEP Must evaluate the purpose-fit obligation `ccpe_h_purpose_binding` (§9.1): the proposed action Must be consistent with the mandate's purpose field according to the deployment's purpose-fit policy. Verdict $\in \{\text{permit}, \text{deny}, \text{constrain}\}$ with optional obligations array. A Phase-1 deny short-circuits.
- b) Phase 2 — Platform-bound enforcement. Data-PDP returns Phase 2 verdict $\in \{\text{permit}, \text{deny}, \text{constrain}\}$ with optional obligations array. The Data-PDP back-end is a deployment-selected catalogue, access-governance overlay, or platform-native engine per §7.
- c) Reconciliation. More-restrictive-wins: $\text{deny} > \text{constrain} > \text{permit}$. Where both phases return constrain, obligations are merged by union. Where Phase 2 returns no verdict within `phase2_timeout_ms` (§3.1.2), the reconciled verdict is derived from the mandate's `fail_disposition`: `fail_closed` reconciles to deny; `fail_drop_egress_only` reconciles to deny for egress-class operations and to permit for non-egress operations where Phase 1 was permit. The Data-PEP Must emit `data.platform_bound.failure` with the diagnostic obligation `phase2_unreachable` populated in the persisted reconciliation record.
- d) Phase-order preservation. Phase 2 Must Not be invoked in parallel with Phase 1, ahead of Phase 1, or as an override of a Phase 1 deny. Violation is a non-conformant variant per §4.6 (CCPE-H-NCO).

Verdict-vocabulary unification note. The single three-value verdict enum $\{\text{permit}, \text{deny}, \text{constrain}\}$ is used consistently across §2.5, §3.3, and §4.4. Obligations (e.g., `ccpe_h_purpose_binding`, `phase2_unreachable`, `audit_persistence_required`, `lineage_attestation_required`, `egress_outside_tenant_denied`, `no_retraining_required`) are carried in a separate obligations: `string[]` array on the Decision Envelope. This aligns the wire contract with RFC 0117 §4 and with RFCs 0150 / 0160 / 0170 / 0180 / 0210 / 0420.

2.6 Deployment Scenarios — S1 / S2 / S3 (Normative)

A CCPE-H-relevant deployment falls into one of three scenarios, all in scope of this RFC. The distinction between in-scope-of-RFC-0165 and conformant-to-G-Data is sharp and load-bearing for §4.5 (Conformance Checklist), §4.5a (Conformance by Scenario), and §4.6 (Non-Conformant Variants): scope is the broader set captured by the Foundation legal framework; conformance is the narrower set that meets the §4.5 bar. All three scenarios below are in-scope; only S2 is conformant to G-Data; S1 and S3 are non-

conformant for the structural reasons given. The audit-trail field `ccpe_h_scenario` (reserved per §9.1) carries the scenario value on the wire.

2.6.1 S1 — Pure Platform-Native Data Authorisation (no Foundation artefact)

Description. The data platform's native access-governance surface alone: the agent presents a platform-issued session credential (a catalogue-side delegated session, an access-governance overlay's masking-policy-bound session, a platform-native warehouse role-and-grant binding, an SSO-mediated workspace token) to the data platform's catalogue / overlay / row-column engine; the platform validates the credential against its own configuration; the platform's policy engine renders the access decision. No Foundation Data-Mandate envelope is constructed; no §4.3 Phase-2 capability contract is invoked against a Foundation envelope; no §3.4 audit-event schema with persistence-before-stream is emitted; no §3.5 lineage-attestation event is emitted; the §2.5 Power-PEP → Data-PDP chain is not operated; no purpose-fit check (`ccpe_h_purpose_binding`, §9.1) is evaluated. This is the shape of essentially every production agent-to-data-platform deployment as of the v0.2 publication date — the gap CCPE-H is designed to close.

Conformance status. S1 is non-conformant to G-Data at the §4.5 conformance bar. Each of the three §4.6 non-conformant variants (CCPE-H-NCI / NCP / NCO) is by default present in S1 because no compensating Foundation-side instrumentation exists: NCI because Phase 1 is absent (no Power-PEP, no purpose-fit check); NCP because no §3.2 cascade is operated against a separable Data-Mandate; NCO because the purpose → dataset-scope → operation phase-class chain is not preserved (the platform's native session credential carries at most an opaque grant, not a three-phase signed chain).

Foundation IP touchpoints. None at the spec-implementation layer. S1 deployments may still touch Foundation IP at three indirect surfaces: (i) the Foundation's CCPE-H-NCI / NCP / NCO taxonomy when describing their non-conformance; (ii) the Foundation's Phase 1 / Phase 2, Power-PEP, Data-PDP terminology when characterising their architectural posture; (iii) the Foundation's Data-Mandate, purpose-fit, lineage-attestation terms-of-art when classifying themselves.

Licensing posture. S1 deployments are subject to the Foundation legal / IPR framework for any descriptive use of Foundation-defined terms-of-art and taxonomies; they are not subject to the Apache 2.0 §3 patent grant of this RFC because they do not implement the specification's normative content. Vendors operating S1 deployments Must Not claim CCPE-H conformance or G-Data conformance (the two terms denote the same §4.5 bar). They May self-classify against the §4.6 non-conformant variant register (e.g., "this deployment corresponds to CCPE-H-NCI + CCPE-H-NCP + CCPE-H-NCO per §2.6.1") for licensing-capture, audit-trail, and gap-analysis purposes; such self-

classification is a negative claim describing distance from the §4.5 bar and is not a conformance claim.

2.6.2 S2 — Two-Artifact via §4.3 Phase-2 Capability (Recommended)

Description. The data platform's native access-governance artefact (catalogue policy attachment, overlay masking session, platform-native role/grant binding) continues to operate at Phase 2 unchanged; a second Foundation-derived artefact — the §3.1 Data-Mandate envelope, conforming to the GiFo-RFC 0115 PoA Credential structure — is constructed by the Authority and presented to the Data-PEP. The Data-PEP runs the §2.5.a Power-PEP pipeline (RFC 0117 16-check + the `ccpe_h_purpose_binding` purpose-fit obligation) at Phase 1, then resolves the Phase-2 surface per §4.2 and submits the proposed action with the resolved dataset reference and the Data-Mandate envelope (or back-end-appropriate projection) per §4.3, receiving the §4.4 verdict envelope. The two verdicts are reconciled at the Data-PEP by the §2.5 more-restrictive-wins rule. The purpose → dataset-scope → operation three-phase parent-chain (§2.1, §3.1 `parent_mandate_id`) is structurally enforced at the Data-PEP; the §3.2 cascade is operated at the Authority; the §3.4 audit-event schema is emitted at every action with persistence-before-stream; the §3.5 lineage-attestation event is emitted for every non-read operation class.

Conformance status. S2 is the conformant scenario for G-Data. The §4.5 conformance checklist items are reachable in S2 and only in S2. The optional §9 CCPE-H Strict and CCPE-H Behörde badges are reachable in S2 only. None of the §4.6 non-conformant variants is structural to S2; an S2 deployment that nonetheless operates one of the variants (e.g., NCP by failing to operate §3.2 cascade) is a non-conformant S2 deployment, distinguishable from S1 / S3 by the wire-level presence of the §3.1 envelope, the §4.3 Phase-2 capability invocation against a Foundation envelope, and the §3.5 lineage-attestation emission.

Foundation IP touchpoints. S2 deployments touch all of: §3.1 (Data-Mandate envelope including the normative purpose field), §3.2 (mandate-chain cascade), §3.3 (Decision Envelope), §3.4 (audit-event schema), §3.5 (lineage-attestation event), §4.2 (Phase-2 surface resolution), §4.3 (Phase-2 capability contract), §4.4 (verdict envelope), §4.6 (variant taxonomy), §6 (cryptographic baseline), §9.1 (reservations catalogue), and the GiFo-RFC 0115 PoA Credential structure.

Licensing posture. S2 deployments are full implementers of this specification's normative content and are subject to the Apache 2.0 §3 patent grant of this RFC under the Legal Notice. The Foundation legal / IPR framework governs all Foundation-IP-bearing artefacts (§3.1 envelope, §3.4 audit schema, §3.5 lineage-attestation event, §4.3 capability contract, §4.6 variant taxonomy).

2.6.3 S3 — Merged-Credential Deployment (vendor extends platform session credential with purpose-shape attributes)

Description. The data-platform vendor extends its native session-credential or catalogue-grant artefact (a delegated session token, a catalogue-side policy-attachment object, an overlay masking-session record, a platform-native warehouse role-binding) to carry purpose-shape claims (principal, purpose, dataset_scope, operations, data_constraints, parent_mandate_id, not_before, not_after) inside the same artefact body rather than constructing a separate Foundation Data-Mandate envelope. The artefact becomes a single hybrid carrying both the platform-bound session authorisation and the purpose-shape claims; there is no second envelope, no §4.3 Phase-2 capability invocation against a Foundation envelope, no separate Power-PEP, and no §2.5 Power-PEP → Data-PDP chain operation. Vendors May reach for S3 as a shortcut to "purpose-fit conformance" without operating the Foundation-side Phase-1 evaluator and without emitting the §3.5 lineage-attestation event in the form §3.5 specifies.

Conformance status. S3 is non-conformant to G-Data. The structural reasons are catalogued at §2.7 below (seven structural disadvantages, with the explicit non-conformance statement at §2.7.8): S3 cannot resolve the architectural pattern that motivates the two-artefact split (the pattern is a governance-model property, not an artefact-format property — adding fields to a single platform-issued artefact does not fix it); S3 leaves the §3.4 audit-event schema unemitted in the principal-signed form (no data.action_decided event anchored on a principal-signed mandate because no separate Power-PEP is operated); S3 leaves the §3.5 lineage-attestation event without a principal-signed envelope to bind to; S3 collapses the §3.2 cascade-revocation lifecycle into the platform's session-credential lifecycle; and any wire-level immutability discipline adopted by S3 in lieu of the §4.3 capability invocation (per §2.7.7) is a Phase-2 artefact-discipline compensation for the absence of the principal-signed three-phase parent chain that S2 supplies structurally.

Foundation IP touchpoints. S3 deployments typically touch: the Foundation's Phase 1 / Phase 2 terminology (often misappropriated as "we cover both phases"); the Foundation's purpose-shape field names (principal, purpose, dataset_scope, operations, data_constraints, parent_mandate_id); the Foundation's CCPE-H-NCI / NCP / NCO taxonomy; the Foundation's purpose-fit and lineage-attestation terms-of-art; and the Foundation's RFC 0115 PoA Credential field semantics.

Licensing posture. S3 deployments that adopt purpose-shape field names from §3.1 (which themselves derive from RFC 0115), variant taxonomy values from §4.6, audit-trail semantics from §3.4, lineage-event semantics from §3.5, or §4.3 Phase-2 capability conventions are subject to the Foundation legal / IPR framework regardless of their non-

conformance to the §4.5 bar. In-scope of RFC 0165 != conformant to G-Data: S3 is in-scope for licensing capture and for normative critique, even though it cannot be declared G-Data conformant.

Conditions under which S3 could approach conformance. If a vendor's S3 design (i) emits the §3.4 audit-event schema at every data-class action with persistence-before-stream, anchored on a principal-signed envelope; (ii) preserves a discrete principal-delegation event that the merged artefact cryptographically references via a principal_evidence-equivalent field; (iii) honours the RFC 0115 §3.7 multi-hop scope-narrowing invariant across the purpose → dataset-scope → operation phase classes; (iv) preserves a discrete §3.2 cascade-revocation handle decoupled from the platform session-credential lifecycle so that revoking authority does not require revoking the platform session; (v) emits the §3.5 lineage-attestation event for every non-read operation class with binding back to the principal-signed envelope; and (vi) carries the artefact over the §4.3 Phase-2 capability contract — then the deployment becomes effectively S2-by-another-name, and may be reclassified accordingly. Until all six conditions are met, S3 remains non-conformant to G-Data.

2.7 Single-Artefact Merged-Mandate Shortcut — Why the §4.3 Phase-2 Capability Is Still Required (Normative)

A vendor may be tempted to treat the architectural argument for two artefacts as a credential-format problem and reach for the S3 single-credential merged-attribute scenario of §2.6.3 — extending its native data-platform session credential with purpose-shape claim fields and declaring victory. This shortcut does not work. The architectural pattern that motivates the two-artefact split is a governance-model property, not a credential-format property; adding fields to a single artefact body does not resolve any of the structural concerns. This subsection enumerates the seven structural disadvantages of S3 against the G-Data conformance bar and states the explicit non-conformance result at §2.7.8.

2.7.1 Purpose-field projection lossiness — the §3.1 purpose semantics cannot survive single-artefact projection

Shape. The §3.1 purpose field is a normative term-of-art whose value Must be drawn from the deployment's purpose vocabulary registered in the Console (§3.1, §3.1.3, §4.5 checklist item three). The Power-PEP's ccpe_h_purpose_binding evaluation (§2.5.a, §9.1) is a per-action re-check against the registered vocabulary at the moment of action, not a one-time issuance-time check. In S3, the merged credential typically projects purpose into a flat session-credential attribute (a JWT claim, a session-record column, a catalogue-grant tag) that the data platform's Phase-2 engine treats as opaque metadata;

the vocabulary registry in the Console is bypassed because the Console is not in the credential-issuance path; the per-action re-check against the registered vocabulary becomes either absent or reduced to a string equality check that does not honour the §3.1 vocabulary-binding semantics. Purpose-fit projection in S3 is lossy by structure, and the `ccpe_h_purpose_binding` obligation cannot be evaluated faithfully because the Power-PEP that owns the evaluation is not operated.

2.7.2 Lineage-attestation provenance gap — the §3.5 event has no principal-signed envelope to bind to

Shape. §3.5 specifies the lineage-attestation event as the post-hoc behavioural-conformance anchor: it cryptographically binds the action's input-dataset references, operation class, and output-artefact reference back to a principal-signed Data-Mandate envelope. The verifiability property is that a downstream reviewer can confirm — from the lineage event alone — that the derived artefact lies within the purpose envelope the principal authorised. In S3, the merged artefact is platform-issued, not principal-signed; there is no principal-signed envelope for the lineage event to bind to. A lineage event emitted under S3 either (a) anchors on the platform-issued artefact, in which case the chain of trust terminates at the platform operator rather than the principal, defeating the post-hoc behavioural-conformance property §3.5 is designed to deliver; or (b) is omitted, in which case CCPE-H-NCI is structural at the lineage layer. S3 deployments cannot deliver §3.5's principal-anchored lineage attestation — a property that no amount of Phase-2 artefact-handling discipline can supply.

2.7.3 Three-phase chain semantics absent — purpose → dataset-scope → operation cannot be enforced inside one artefact

Shape. §2.1 establishes the three sequential phase classes (purpose → dataset-scope → operation); §3.1 `parent_mandate_id` carries the chain on the wire; §2.5.d phase-order preservation forbids out-of-order or parallel evaluation. The chain is enforced at the Data-PEP at every action against principal-signed envelopes for each phase class. S3's single-artefact design has no native chain primitive: a dataset-scope-phase and operation-phase action in S3 are typically evaluated against the same merged credential whose claims were signed once at issuance time, with no per-phase signed envelope to bind the chain. The RFC 0115 §3.7 scope-narrowing invariant cannot be cryptographically enforced across S3 phase transitions because each phase does not carry an independent envelope with chain-binding cryptographic material. S3 deployments cannot honour purpose → dataset-scope → operation scope-narrowing at the artefact layer; the §4.3 capability layer is the only place where the three-phase chain can be enforced. CCPE-H-NCO is consequently structural in S3.

2.7.4 Lifecycle entanglement — §3.2 cascade-revocation unreachable

Shape. S2 separates the artefact lifecycle (Phase 2, platform-side, governed by the platform's own session-credential / grant TTL) from the authority lifecycle (Phase 1, Authority-side, governed by §3.2 mandate-chain cascade). S3 collapses the two: revoking the merged artefact revokes both the platform session validity and the asserted authority simultaneously; revoking authority alone (e.g., the principal withdraws the purpose-bound mandate but the underlying platform session remains valid for non-agent use by the same human user) requires invalidating the platform session, which is a heavier and platform-coupled operation than an Authority-side cascade emission. The §3.2 invariant — that revoking a parent mandate cancels all in-flight platform-side derivations — cannot be operated when there is no separable parent mandate to revoke against. S3 deployments cannot independently revoke authority while preserving the platform session credential, and cannot operate §3.2 cascade at all — a cardinal property of the Phase-1 / Phase-2 separation that the §4.3 capability preserves and that the §4.5 conformance bar requires.

2.7.5 Cap-and-scope drift on dataset-scope — Authority-side mutation invisible to issued credential

Shape. In S3, the merged credential is signed at issuance time and carries the purpose-shape claims (`dataset_scope`, `operations`, `data_constraints`, `not_after`) as static body fields. After issuance, the principal's actual delegation surface continues to live at the Authority (per §2.4.b) and continues to mutate by Authority-side write — the principal narrows the dataset scope (drops a sensitive table), tightens the operations set (withdraws egress), strengthens the `no_retraining` constraint, raises the egress-tenant boundary. The merged credential's purpose-shape claims now drift silently from the Authority's state until the credential expires or is re-issued. The freshness contract that §3.1.1 (parent-chain-state freshness) requires is not native to S3 because S3's single-artefact design treats authority as an issuance-time snapshot, not as a continuously-Authority-evaluated surface. A downstream Phase-2 evaluator that accepts a stale merged credential authorises an action the principal no longer permits; S2's §3.1.1 ceiling closes this gap by requiring a fresh parent-chain check at every action, with `parent_chain_invalid` (§9.1) emitted as an obligation when the bound is exceeded. S3 deployments inherit cap-and-scope drift on dataset-scope as a structural vulnerability.

2.7.6 Cross-substrate interoperability break — vendor-specific wire format

Shape. S2's Data-Mandate envelope conforms to the GiFo-RFC 0115 PoA Credential structure and is carried over the §4.3 Phase-2 capability contract; the same envelope

shape is honoured across every Phase-2 substrate listed at §7 (catalogue, overlay, platform-native engine), with substrate-specific projections handled at the back-end-appropriate-projection step of §4.3. A CCPE-H downstream consumer (an audit-aggregator, a regulator-bound export per §13(h), a cross-platform lineage reviewer per §3.5) can validate the envelope without per-substrate knowledge. S3's merged credential is a substrate-specific wire format — every catalogue, overlay, and platform-native engine extends its own native artefact in its own way; there is no shared shape, no shared capability contract, no shared validator. A CCPE-H downstream consumer cannot validate S3 merged credentials without a per-substrate parser, and cross-substrate portability of the principal's mandate (the ability to take the same Data-Mandate to Substrate A and Substrate B and have it evaluated identically at Phase 1) is lost. S3 breaks cross-substrate interoperability — the very property the §4 engine-neutral architecture is designed to preserve. Each substrate's S3 wire format becomes a per-substrate balkanisation of the data-mandate layer, defeating the cross-substrate interoperation goal that motivates the §4 architecture and undercutting the regulator-bound aggregated-audit-trail export deferred to §13(h).

2.7.7 Governance-model versus credential-format — the category error

Shape. The architectural pattern that motivates the §3.1 envelope plus the §4.3 Phase-2 capability is a property of the governance model — how authority is purpose-bound, recorded, mutated, narrowed, revoked, evidenced via lineage, and reconciled across the credential-bound and platform-bound flows — not a property of the artefact format. Purpose-vocabulary registry binding (§2.7.1) is a property of where purpose vocabulary lives, not what shape the credential takes. Three-phase chain enforcement (§2.7.3) is a property of how the purpose → dataset-scope → operation delegation chain is recorded and enforced, not what fields the credential carries. Cascade-revocation (§2.7.4) is a property of which lifecycle the revocation operates on, not what the wire-level credential carries. Lineage-attestation provenance (§2.7.2) is a property of what the lineage event cryptographically binds back to, not what fields the credential exposes. Adding purpose-shape attributes to a single platform-issued artefact body does not change the governance model; it only encodes a snapshot of the governance model at credential-issuance time and projects it through the platform's session lifecycle. The §4.3 capability changes the governance model by introducing a discrete Foundation-instrumented Phase-1 evaluation step that re-evaluates the Authority at every action; S3 cannot reach that change by credential-format alone.

2.7.8 Explicit non-conformance statement

S3 is non-conformant to G-Data and Must Not be declared at the §4.5 conformance bar — regardless of whether an S3 deployment additionally adopts a Phase-2 artefact-immutability discipline, an issuance-time purpose-vocabulary cross-check, or any other Phase-2 credential-discipline compensation. Vendors operating S3 deployments who wish to claim G-Data conformance Must implement the §4.3 Phase-2 capability contract against a §3.1 Data-Mandate envelope, operate the §2.5 Power-PEP → Data-PDP chain (including the §2.5.a ccpe_h_purpose_binding purpose-fit check), emit the §3.4 audit stream with persistence-before-stream, and emit the §3.5 lineage-attestation event for non-read operation classes — at which point, by the conditions enumerated at §2.6.3, the deployment becomes S2 by another name and the conformance assessment proceeds against the §4.5 checklist. The §4.3 capability is not a sidecar that S3 obviates; it is the central operational mechanism that S3 cannot reach by extending the platform session credential alone, and that wire-level credential-handling disciplines compensate for only at the artefact-handling integrity layer, not at the governance-architecture layer.

3. Data-Mandate Envelope and Decision Surface

3.1 Data-Mandate Envelope

The Data-Mandate envelope is a Power-of-Attorney credential per RFC 0115 specialised for the data-authorisation domain. Required fields:

`mandate_id` — URI.

`parent_mandate_id` — URI or null. Carries the §3.2 mandate chain.

`principal` — RFC 0115 principal reference.

`subject` — agent identifier.

`purpose` — non-empty string drawn from the deployment's purpose vocabulary (e.g. customer-segmentation, fraud-investigation, regulatory-reporting, model-evaluation, model-training); the deployment's purpose vocabulary is registered in the Console per §3.1.3 (the registration-presence-at-issuance obligation that the Authority enforces against this field).

`dataset_scope` — set of dataset-scope expressions (catalogue refs, schema globs, classification tags, exclusion clauses).

`operations` — set drawn from {read, aggregate, derive, write, egress, train}.

`data_constraints` – object carrying `tenant-egress-boundary`, `retention-ceiling`, and `no_retraining` (where applicable) constraints.

`not_before`, `not_after` – RFC 3339 timestamps.

`fail_disposition` – `fail_closed` | `fail_drop_egress_only`.

`phase2_timeout_ms` – non-negative integer; deployment-declared Phase-2 timeout per §3.1.2.

`signature` – JWS per §6.1.

`issued_at` – monotonic timestamp per §6.7.

`kid` – references a key in Authority's JWKS.

`audit_correlation.trace_id` – W3C Trace Context.

3.1.1 Parent-Mandate-State Freshness

Where `parent_mandate_id` is non-null, the Data-PEP Must observe a parent-mandate state no older than the deployment's `parent_chain_state_staleness_ceiling` (default ≤ 5 s; Strict reserves ≤ 1 s; Behörde reserves ≤ 1 s with audit-bound time-source attestation). Staleness exceedance Must be treated as `phase2_unreachable` per §2.5.c.

3.1.2 Phase-2 Timeout Declaration

`phase2_timeout_ms` carries the deployment-declared Phase-2 timeout, measured from the moment the Data-PEP issues the Phase-2 query to the moment a verdict is fully received at the Data-PEP. Wall-clock measured from the Data-PEP's monotonic clock. Default 1500 ms; Strict reserves ≤ 750 ms; Behörde reserves ≤ 500 ms.

3.1.3 Purpose Vocabulary Registry

The deployment-controlled purpose vocabulary referenced by the §3.1 `purpose` field is a Console-administered, deployment-controlled list of free-text purpose identifiers. The single normative obligation v0.7 places on the registry is registration-presence: every value carried in a §3.1 `purpose` field Must be present in the registered vocabulary at the time of mandate issuance. The Authority Must reject an issuance request whose `purpose` value is not in the registered list at the moment of issuance and Must Not back-fill the registry implicitly. Lifecycle, format constraints (case-folding, length bounds, reserved-prefix conventions), and cross-deployment portability of vocabulary identifiers are deferred to a future release and tracked at §13(u). Registration mechanics (CRUD surface, audit-event taxonomy for vocabulary mutations, multi-

tenant scoping) are likewise out of scope at v0.7 and follow the deployment's Console-administration conventions.

3.2 Data Power-of-Attorney (Data-PoA)

A Data-PoA is the lifecycle aggregation of a purpose-class, dataset-scope-class, and operation-class mandate under a shared `audit_correlation.trace_id` and shared parent chain. Cascade-revocation: revocation of any mandate in the chain Must revoke every descendant mandate and emit `data.cascade.revoked` per descendant. Scope-narrowing invariant: every descendant's `dataset_scope` Must be a subset of the closest non-null ancestor's `dataset_scope`; every descendant's operations set Must be a subset of the closest non-null ancestor's operations set.

3.3 Data-PEP and the Decision Envelope

The Data-PEP at Phase 1 produces a Decision Envelope:

```
{
  "verdict":      "permit" | "deny" | "constrain",
  "obligations": [ ... ],
  "phase":       "phase1",
  "trace_id":    "<W3C trace-id>"
}
```

The ``obligations`` array carries any subset of the §9.1 reserved obligation values (``ccpe_h_purpose_binding``, ``lineage_attestation_required``, ``egress_outside_tenant_denied``, ``no_retraining_required``, ``phase2_unreachable``, ``audit_persistence_required``, ``parent_chain_invalid``, ``mandate_already_consumed``); the example below is illustrative, not exhaustive.

Example — ``permit`` with two obligations:

```
{
  "verdict":      "permit",
  "obligations": ["ccpe_h_purpose_binding",
    "lineage_attestation_required"],
  "phase":       "phase1",
}
```

```
"trace_id":      "00-4bf92f3577b34da6a3ce929d0e0e4736-
00f067aa0ba902b7-01"
}
```

Verdict semantics:

permit — the action is authorised. An empty obligations array means unconditionally permitted. A non-empty obligations array means permitted subject to the listed obligations being honoured by the caller.

deny — the action is refused. The obligations array carries the diagnostic reason codes.

constrain — the action is permitted in narrowed form. The obligations array carries the constraint instructions.

The set of obligation strings is reserved at §9.1.

3.4 Data Audit Trail

Reserved event types:

Event type	When
<code>data.action_proposed</code>	Phase 1 invoked
<code>data.action_decided</code>	Phase 1 verdict produced (un-suffixed form; reserved for non-metered Phase-2 evaluators that do not flow through the §6.5a slot-registry recorder, including PaC-extension-point Phase-2 evaluators per §13.A.7 and v0.2-conformant deployments that do not adopt the §13.A foundation)
<code>data.action_decided.metered</code>	Phase-2 verdict flowing through the §6.5a.2 <code>`recordDataDecision()`</code> recorder of a slot-registered <code>`data_pdp`</code> instance (reserved at §13.A.5)
<code>data.platform_bound.invoked</code>	Phase 2 invoked
<code>data.platform_bound.decided</code>	Phase 2 verdict received
<code>data.platform_bound.failure</code>	Phase 2 unreachable / errored / mismatch
<code>data.cascade.revoked</code> cascaded to platform	Authority-side mandate revocation
<code>data.purpose_attested</code>	Purpose-fit <code>ccpe_h_purpose_binding</code> evaluated and recorded

`data.lineage_recorded` Per §3.5

`data.lineage_attestation.recorded` Emitted by
``recordLineageAttestation()`` per §6.5a.3 (reserved at §13.A.5)

Event-emission cardinality (Normative). When the Phase-2 verdict flows through the §6.5a.2 ``recordDataDecision()`` recorder of a slot-registered ``data_pdp`` instance, the metered envelope ``data.action_decided.metered`` Must replace ``data.action_decided`` for that decision; the deployment Must Not double-emit both forms for the same decision. The un-suffixed ``data.action_decided`` form is reserved for non-metered Phase-2 evaluators that do not flow through the slot-registry recorder — in particular for PaC-extension-point Phase-2 evaluators per §13.A.7 and for v0.2-conformant deployments that do not adopt the §13.A foundation. Downstream audit consumers Must accept either form on the wire and Must treat the suffixed and un-suffixed events as semantically equivalent for the purposes of conformance evaluation against §3.4 / §4.5.

Persistence-before-stream invariant. Audit events Must be persisted at the Console event store before any out-of-process streaming subscriber is notified.

3.5 Lineage-Attestation Event

For every permitted action whose operation class is one of {aggregate, derive, write, egress, train}, the Data-Runtime Must emit a `data.lineage_recorded` event:

```
{
  "mandate_id":      "<URI>",
  "trace_id":        "<W3C trace-id>",
  "input_datasets":  ["<dataset-ref>", "..."],
  "operation_class": "aggregate" | "derive" | "write" |
  "egress" | "train",
  "output_artefact": "<artefact-ref or null>",
  "purpose":         "<purpose string carried from mandate>",
  "obligations_honoured": ["lineage_attestation_required",
  "..."],
  "emitted_at":      "<RFC 3339 timestamp>"
}
```

The `input_datasets` and `output_artefact` references Must be drawn from the deployment's catalogue identifier scheme (§7) so that downstream reviewers can resolve the references against the platform's own catalogue. The event is the post-hoc verifiability anchor for behavioural conformance to the mandate's stated purpose.

A read-only operation class (`read`) does not require lineage attestation; the action is recorded by `data.action_decided` (or `data.action_decided.metered` per §3.4 cardinality) only.

4. Engine-Neutral Architecture and Conformance

4.1 Architectural Placement

CCPE-H specifies the engine-neutral integration architecture. It does not mandate a single normative integration substrate; the deployment's Data-PDP back-end is selected per §7 and is one of: an enterprise data-governance catalogue (§7.1–§7.5), an access-governance overlay (§7.6), or a platform-native catalogue (§7.7–§7.9).

4.2 Phase-2 Surface Resolution

The Data-PEP Must resolve the Phase-2 surface by deployment configuration, registered in the Console. The configuration Must name (i) the back-end class, (ii) the back-end's API endpoint, (iii) the auth scheme, and (iv) the Phase-2 timeout. The selected back-end Must be accompanied by a §7-anchored cookbook entry.

4.3 Phase-2 Capability Contract

The Data-PEP submits the proposed action together with the resolved dataset reference and the Data-Mandate envelope (or a back-end-appropriate projection thereof) and receives the §4.4 verdict envelope. Transport per §6.3.

4.4 Phase-2 Verdict Envelope

```
{
  "verdict":      "permit" | "deny" | "constrain",
  "obligations": [...],
  "phase":        "phase2",
  "phase2": {
```

```

    "platform_evidence": { /* opaque platform-side evidence
blob */ }

    },

    "trace_id":      "<W3C trace-id>"

}

```

The Phase-2 verdict envelope uses the same three-value verdict enum and the same obligations array shape as the Phase-1 envelope at §3.3.

4.5 Conformance Checklist

A deployment claims G-Data Conformance if and only if it satisfies:

- §2.4 three-service pattern (no role conflation);
- §2.5 Power-PEP → Data-PDP chain operated for every data-class action;
- §3.1 envelope shape (including purpose field non-empty and drawn from a registered vocabulary per §3.1.3);
- §3.1.1 freshness ceiling for the active profile;
- §3.3 Decision Envelope vocabulary ({permit, deny, constrain} + obligations array) including evaluation of ccpe_h_purpose_binding;
- §3.4 audit stream emission with persistence-before-stream and event-emission cardinality preservation;
- §3.5 lineage-attestation emission for all non-read operation classes;
- §4 Phase-2 surface resolution and capability contract;
- §6 cryptographic baseline (incl. §6.2 canonicalisation, §6.3 transport);
- §7 cookbook anchor for the deployment's selected Phase-2 back-end (one of §7.1–§7.9, or a deployment-declared additional cookbook registered against §7.10 extension hook).

4.5a Conformance by Deployment Scenario (S1 / S2 / S3)

The §2.6 deployment scenarios map to the §4.5 conformance bar as follows. In-scope of RFC 0165 != conformant to G-Data. All three scenarios are in-scope of this RFC for licensing-capture and normative-critique purposes; only S2 is conformant to G-Data.

Scenario (per §2.6)	G-Data conformant	CCPE-H Strict
(§9)	CCPE-H Behörde (§9)	Default §4.6 variants
present	Reason for non-conformance (where applicable)	
S1 – Pure Platform-Native	Non-conformant	Non-conformant
Non-conformant	NCI + NCP + NCO by default	No §3.1
envelope; no §4.3 Phase-2 capability invocation against a		

Foundation envelope; no §2.5 chain; no ccpe_h_purpose_binding evaluation; no §3.4 audit-event schema with persistence-before-stream; no §3.5 lineage-attestation event; no §3.2 cascade.

S2 — Two-Artefact via §4.3 Capability Conformant
Reachable Reachable None structural; per-
deployment variants possible —

S3 — Merged-Credential Non-conformant Non-conformant Non-conformant
NCO structural per §2.7.3; NCI structural at the lineage layer per §2.7.2; NCP structural per §2.7.4 §2.7
seven structural disadvantages — purpose-field projection lossiness (§2.7.1), lineage-attestation provenance gap (§2.7.2), three-phase chain unreachable inside one artefact (§2.7.3), §3.2 cascade unreachable (§2.7.4), cap-and-scope drift on dataset-scope (§2.7.5), cross-substrate interoperability break (§2.7.6), governance-model-vs-credential-format category error (§2.7.7); the §4.3 capability is unreachable by extending the platform session credential alone.

Determination procedure. A G-Data Conformance Statement Must name (i) the deployment's scenario per §2.6 (S1 / S2 / S3); (ii) the per-item disposition against the §4.5 checklist; (iii) the applicable §4.6 variant codes (if any); (iv) the audit-trail evidence supporting (i)–(iii). The audit-trail field ccpe_h_scenario (reserved per §9.1) carries the scenario value on the wire.

Cross-validation. A §4.5-checklist determination of conformant combined with a §2.6 scenario of S1 or S3 is rejected by the Conformance Statement reviewer; the deployment Must either (a) move to S2 by operating the §4.3 Phase-2 capability against a §3.1 Data-Mandate envelope, the §2.5 chain (including the ccpe_h_purpose_binding purpose-fit check), the §3.4 audit-event schema, and the §3.5 lineage-attestation event, or (b) restate its scope so that the conformance claim is explicitly limited to the §4.6 non-conformant variant register.

4.6 Non-Conformant Variants — CCPE-H-NCI / NCP / NCO

- a) CCPE-H-NCI — No Credential-bound Integration. Deployment runs Phase 2 only; Phase 1 absent (no Power-PEP, no purpose-fit check). Audit-tag prefix ccpe-h-nci-*.
- b) CCPE-H-NCP — No Cascade-revocation Propagation. Phase 1 + Phase 2 but no §3.2 cascade. Audit-tag prefix ccpe-h-ncp-*.
- c) CCPE-H-NCO — No Conformant-Order Preservation. Deployment performs Phase 1 / Phase 2 but does not preserve the purpose → dataset-scope →

operation phase-class chain, or invokes Phase 2 ahead of or in parallel with Phase 1. Audit-tag prefix `ccpe-h-nco-*`.

Scenario-thread. S1 deployments (§2.6.1) carry CCPE-H-NCI + CCPE-H-NCP + CCPE-H-NCO by default because no §3.1 envelope, no §3.2 cascade, and no phase-class chain are operated. S3 deployments (§2.6.3) carry CCPE-H-NCO structurally per §2.7.3 (the chain cannot be enforced inside a single platform-issued artefact), CCPE-H-NCI structurally at the lineage layer per §2.7.2 (the §3.5 event has no principal-signed envelope to bind to), and CCPE-H-NCP structurally per §2.7.4 (the §3.2 cascade cannot be operated against a separable mandate). S2 deployments (§2.6.2) do not carry any §4.6 variant structurally; an S2 deployment that nonetheless operates one of the variants is a non-conformant S2 deployment whose specific variant is recorded in the audit trail.

Footnote. The NCI / NCP / NCO acronyms are profile-local. Their CCPE-A / B / C / D / E / F / G counterparts in the sibling RFCs carry parallel letters but per-family-distinct dimensions. Audit-trail consumers Must Not parse the bare three-letter acronym out of context; the `ccpe-h-*` prefix disambiguates.

5. Concept Mapping — GAuth/CCPE ↔ Data-Platform Substrates (Informative)

GAuth/CCPE concept	Data-platform concept
Data-Mandate envelope (§3.1)	Catalogue policy attached to a delegated session
purpose (§3.1)	Catalogue purpose / use-case tag (where the platform expresses one)
dataset_scope (§3.1)	Catalogue asset-set expression (schema glob / classification filter)
operations (§3.1)	Catalogue action grant set
Phase-1 verdict envelope (§3.3)	(No direct counterpart – credential-bound layer is absent in the platform-bound model)
Phase-2 verdict envelope (§4.4)	Catalogue / overlay / platform-native authorisation response
Data-Runtime (§2.4)	Query engine / data-access layer / processing host
Data-PDP (§2.4)	Catalogue policy engine / access-governance overlay / platform-native engine
Cascade-revocation pipeline (§3.2)	Catalogue policy retraction / session revocation

Lineage-attestation event (§3.5) Platform lineage record (where the platform records lineage natively)

The mapping is intentionally lossy in two directions: (i) the platform-bound model has no credential-bound counterpart for the Phase-1 verdict; (ii) the credential-bound model carries purpose as a first-class field that most platform-bound models do not. The bridging discipline is left to the §7 cookbooks.

6. Cryptographic Requirements

6.1 Signature Algorithms

The Data-Mandate signature field Must use a signature algorithm permitted by RFC 0115 §5.4, applied as a JWS per RFC 7515 over the §6.2-canonicalised payload. Within the RFC 0115 set:

Algorithm	CCPE-H preference	Rationale
EdDSA (Ed25519)	Recommended	Constant-time verification, minimal envelope footprint, parity with RFC 0115 §5.4(a)
ECDSA (ES256)	Acceptable	Universal availability in HSMs; parity with RFC 0115 §5.4(b)
RSA-PSS	Permitted, deprecated	Carried for legacy Authority deployments only

Profile-specific overrides:

Behörde (reserved): EdDSA Required; ES256 acceptable only with HSM-bound key attestation.

Strict (reserved): EdDSA Recommended; RSA-PSS not permitted.

The kid header parameter Must reference a key published in Authority's JWKS endpoint per RFC 7517.

6.2 Canonicalisation

Every signed mandate body and every HMAC-signed cross-service request body Must be canonicalised per RFC 8785 (JSON Canonicalization Scheme, JCS) prior to signature computation. The §6.1 JWS signs the canonicalised payload bytes, not the wire-form payload bytes. Implementations that Do Not canonicalise prior to signature Must Not be considered conformant.

The canonicalisation step is the normative anchor that two independent implementations Must agree on the exact byte sequence under signature; absent this anchor, structurally-equivalent JSON encodings (key-ordering, whitespace, number-form) would produce divergent signatures and break cross-implementation verifiability.

6.3 Transport

All Console ↔ Authority, Console ↔ Data-Runtime, Authority ↔ Data-Runtime, and Data-PEP ↔ Data-PDP traffic Must use TLS 1.3 or higher. Mutual authentication is Required where both peers present TLS client certificates issued under a deployment-controlled CA; this applies in particular to the Phase-2 capability invocation between the Data-PEP and the Data-PDP where the Data-PDP is co-deployment-operated.

Where the Data-PDP is operated by a counterparty (e.g. a SaaS catalogue) whose TLS posture the deployment does not control, the deployment Must record the negotiated TLS profile (version, cipher suite, peer certificate fingerprint) into the §3.4 `data.platform_bound.invoked` audit event for post-hoc verifiability.

6.4 Key Rotation

Authority signing keys Must rotate at least every 365 days; Strict reserves 90 days; Behörde reserves 30 days. Old keys remain in the JWKS endpoint for verification of in-flight mandates until all such mandates have expired.

6.5 Audit Signature

`data.cascade.revoked` and `data.lineage_recorded` events Must carry an Authority signature; lineage attestations are the post-hoc verifiability anchor and Must Not be repudiable by the Data-Runtime.

6.5a Per-Call Metering and Open-Core Symmetry Rules (Normative)

This subsection specifies the per-call metering recorders that any reference operator Must apply when a Data-Decision verdict is produced or a Lineage-Attestation event is recorded. These rules realise the open-core symmetry invariants of §13.A.4 against the Data-PDP and Data-Authority slots, mirroring the equivalent §6.5 rules for the Identity-Bridge in RFC 0210 v0.7 and the equivalent §3.5 rules for Commerce-Decision in RFC 0170 v0.9.1.

6.5a.1 Metering Discipline

Every Data-Decision verdict and every Lineage-Attestation emission Must flow through the reference operator's ``recordDataDecision()`` / ``recordLineageAttestation()`` recorders before being treated as accepted. The recorders Must apply the four invariants of §13.A.4, Must persist to the unified-audit envelope ``[Audit] <type> <json>`` (no plain console.log lines), and Must carry the ``phase2_evaluation.profile`` partitioning key per §15.3.

6.5a.2 Data-Decision Metering — ``recordDataDecision()``

```
recordDataDecision({  
  platformId,           // Required. Must reference a  
                        // registered data_pdp instance.  
  mandateId,           // Required.  
  traceId,             // Required (W3C Trace Context).  
  verdict,             // "permit" | "deny" | "constrain"  
  obligations,         // string[] (separate from verdict per  
                        // §3.3 unification).  
  operationClass,      // one of {read, aggregate, derive,  
                        // write, egress, train}  
  ccpe_h_scenario,     // S1 | S2 | S3, mirrors per-instance  
                        // config.  
  phase2_evaluation: {  
    profile,           // one of the §15.3 reserved values.  
    profiles?: [...], // for cascade events spanning multiple  
                        // Data-PDPs.  
  },  
  meteredAt            // RFC 3339.  
}) → MeteringResult { billable, reason }
```

Invariants:

- (1) Unknown ``platformId`` fails closed. A ``recordDataDecision()`` call against a ``platformId`` that is not in the reference operator's ``listDataPdps()`` map Must return `{ billable: false, reason: "unknown_platform_id_fail_closed" }` and Must Not participate in the metering aggregation.

- (2) ``operatorMode = "user_self_hosted"``` is never billable. Independent of tariff tier, a self-hosted operator-mode instance Must Not incur a billable meter; the recorder returns `{ billable: false, reason: "user_self_hosted_zero_variable" }`.
- (3) Tariff O coerces non-billable. At Tariff O the recorder Must return `{ billable: false, reason: "tariff_o_non_billable" }`; if the configured ``operatorMode`` is ``gimel_managed`` the recorder Must additionally emit a structured warning log entry (`[ConnectorSlotRegistry] tariff_o_gimel_managed_warning ...``) for operator review. (Reason-population mandate carried from v0.5.1; symmetry with invariants (1) and (2) is uniform across the four invariants.) (Layering note, carried from v0.5: §13.A.4 makes ``gimel_managed`` + Tariff-O a hard registration-time error; the registration validator refuses such registrations and they Must Not exist at runtime. The (3) runtime warning is a defence-in-depth fall-back for the case where such a registration somehow does exist at runtime — for instance, after a config import that bypassed the validator, or during an upgrade that introduced the §13.A.4 guard against pre-existing state. A correctly-operating reference operator at v0.7 should never see the warning fire in practice.)
- (4) Tariff G coerces to M at lookup. Tariff G is internal-Gimel-dev-only and Must Not appear in customer-facing billing aggregation; the recorder treats Tariff G as Tariff M for the duration of the metering decision (see §15.1 and the Two-Hats Footnote at §6.5a.5). The lookup-time coercion does not populate a customer-facing ``MeteringResult.reason`` value; the recorder treats the decision as the post-coercion Tariff-M decision for downstream audit-reason purposes.

6.5a.3 Lineage-Attestation Metering — ``recordLineageAttestation()``

```
recordLineageAttestation({  
  mandateId, traceId, inputDatasets[], operationClass,  
  outputArtefact, purpose, obligationsHonoured[],  
  authoritySignature?, // when a data_authority is  
  registered  
  meteredAt  
}) → MeteringResult { billable, signed, reason }
```

Same four invariants as §6.5a.2, plus:

Graceful Authority degradation. If no ``data_authority`` is registered, ``recordLineageAttestation()`` Must Not fail; it Must emit a structured warning log entry indicating that no Authority signature was applied (Informative example,

JavaScript reference operator:

```
`console.warn("[ConnectorSlotRegistry]
data_authority_unregistered ...")`), set `signed = false` on
the result, and proceed with the unsigned attestation. The
structured-warning obligation is portability-preserving – non-
JavaScript reference operators (Go, Rust, Python; see §13.A.8)
Must emit an equivalent structured warning through their host-
language logging facility, not a `console.warn` literal. The
`data.lineage_attestation.recorded` audit event carries
`signed: false` and the reviewer is on notice that the
Foundation post-hoc verifiability anchor (§6.5) is incomplete
for that emission. Honoured Authority signatures set `signed =
true`.
```

6.5a.4 In-Memory Metering Log Cap

Each recorder Must maintain an in-memory ring buffer of recent `MeteringResult` records bounded by the `meteringLogCap` config field on the slot (default 1 000 records per recorder). The cap is per-recorder, configurable at slot registration time, and surfaces through the slot's `getMeteringStats()` accessor. Older entries are evicted in FIFO order; persistent storage of metering aggregates is the operator's responsibility and is out of scope of this subsection.

(Informative.) The default `meteringLogCap = 1000` is calibrated for development and low-volume deployments where the in-memory ring buffer is the primary inspection surface for recent metering activity. Production data-platform substrates whose Phase-2 traffic materially exceeds 1 000 decisions per recorder over the desired inspection window Should configure a higher cap at slot registration time, sized against the deployment's expected per-recorder QPS and the operator's persistent-aggregate flush cadence. Operators that ship metering aggregates to an external store (warehouse, SIEM, billing back-end) at sub-second cadence may retain the default cap regardless of QPS.

6.6 Trace-Context Binding

Every signed envelope Must bind the W3C Trace Context `trace_id` into the signed payload.

6.7 Replay Defence

Authority-issued envelopes Must carry monotonic issued_at. Verifiers Must reject envelopes outside a deployment-declared clock-skew window (default ± 60 s; Strict ± 10 s; Behörde ± 5 s).

6.8 Key-Rotation / Revocation Orthogonality

Rotation bounds key-compromise blast radius only; revocation is via §3.2 cascade + RFC 0118 introspection, independent of rotation cycle.

6.9 PQC Migration

Deferred until the GAuth credential-layer RFCs (0115 / 0116 / 0117) themselves migrate. Open-core scope; tracked at §13(e).

6.10 Security Considerations

The CCPE-H threat surface comprises:

- a) credential forgery / replay against the Power-PEP (mitigated at §6.7 / §6.8);
- b) data-platform-side policy bypass against the Data-PDP (mitigated by deployment selection of the §7 back-end and by §6.3 transport assurance);
- c) phase-order violation enabling Phase-2 permission to mask absent or denied Phase-1 purpose-fit (CCPE-H-NCO; classified at §4.6);
- d) cascade-revocation omission permitting in-flight read / derive / egress under a revoked mandate (CCPE-H-NCP; mitigated at §3.2 cascade);
- e) audit-trail tampering at Console (mitigated by the §3.4 persistence-before-stream invariant and §6.5 audit signature);
- f) Authority signing-key compromise (mitigated by §6.4 rotation and §6.5 cascade revocation under compromised kid);
- g) lineage-attestation repudiation by a misbehaving Data-Runtime (mitigated at §6.5 — data.lineage_recorded events Must carry an Authority signature, not solely a Runtime signature);
- h) canonicalisation drift between implementations causing signature non-verification (mitigated at §6.2);
- i) TLS-profile drift on counterparty-operated Data-PDP (mitigated at §6.3 — negotiated profile recorded into the §3.4 audit event for post-hoc verifiability);
- j) purpose-vocabulary drift between Console-registered and Data-Mandate-issued purpose strings, leading to silent purpose-fit fail-open (mitigated by §3.1.3 registration-presence-at-issuance obligation enforced by the Authority);

- k) substrate-side classification staleness (where the catalogue's classification of an asset has changed since the Data-Mandate was issued) — mitigated by §3.1.1 freshness ceilings on parent-mandate state and by a complementary asset-classification freshness ceiling at the Data-PEP.

The §1.5 Normative Technology Exclusions and the Legal-Notice carve-outs (AI-enabled Governance, Web3-Integration, DNA-based Identity, PQC-bound commercial variants of the foregoing) are not in-scope security domains for this RFC; the security posture for those domains is governed by separate Gimel Technologies commercial licenses.

Trust-boundary conflations (Must). Conformance audits Must verify that no two of {Console, Authority, Data-Runtime} share the same operational identity, signing key, or persistence layer. This audit-side check is the operational realisation of the §2.4 three-service-pattern conformance item and the §4.5 conformance-checklist item "§2.4 three-service pattern (no role conflation)"; failure of any of the three sub-checks (operational identity, signing key, persistence layer) is a §4.5 conformance failure, not solely an audit-hygiene observation.

7. Cookbook Bodies (Informative)

This section provides full cookbook bodies for nine data-platform substrates, grouped into three families. Each cookbook documents

- (i) the concrete Phase-2 integration surface (substrate API endpoints invoked by the Data-PEP),
- (ii) the concrete projection of Data-Mandate fields (purpose, dataset_scope, operations, data_constraints) onto the substrate's native policy primitives,
- (iii) the concrete reconciliation rule applied where the substrate exposes multiple internal engines, and
- (iv) the concrete §3.5 lineage-attestation source. Cookbook bodies are informative; the §4.5 conformance checklist is the normative anchor.

All API references are to publicly-documented platform surfaces as of v0.2 publication (carried verbatim into v0.7). Where a platform's API evolves, deployments are expected to track the §7.10 extension-hook discipline.

(Informative.) Where a deployment registers its chosen Phase-2 back-end as a ``data_pdp`` slot instance per §13.A.2, the cookbook body of §7.1–§7.10 is the authoritative substrate-side reference; the §13.A.2 registration carries the ``cookbookSection`` field naming which §7.x body applies (e.g., ``cookbookSection` = "7.6.immuta"` or ``cookbookSection` = "7.10:trino-pac"`). The §7.x identifier shape is reserved at §15.5.

Family 1 — Enterprise Data-Governance Catalogues

7.1 Collibra

Phase-2 integration surface. Collibra Data Intelligence Platform. The Data-PEP invokes:

GET /rest/2.0/assets and POST /rest/2.0/assets/search to resolve dataset_scope against Collibra Catalog asset URIs;

POST /rest/protect/v1/policies/evaluate (Collibra Protect policy-evaluation surface) to obtain the row/column / classification verdict;

GET /rest/2.0/lineage/relations to resolve input-dataset references for §3.5 emission.

Authentication is OAuth2 client-credentials against Collibra's /auth/realms/collibra/protocol/openid-connect/token endpoint; the issued access token is bound to a deployment-controlled service principal whose Catalog role is Steward (read) plus Protect Policy Evaluator.

Projection rules — Data-Mandate → Collibra primitives.

dataset_scope → Collibra asset-set expression. A scope clause acme.warehouse.customers.* minus tag:PII projects to the Collibra Search-API filter { "domain": "acme.warehouse", "name": "customers.*", "excludeTags": ["PII"] }.

purpose → the Collibra Protect rule's purpose attribute (Collibra Protect rules carry a free-text purpose dimension; the deployment registers its purpose vocabulary as Collibra Protect rule labels under domain gifo.purposes).

operations → Collibra Protect rule actionGrants (READ, AGGREGATE, DERIVE, WRITE, EGRESS, TRAIN).

data_constraints.tenant_egress_boundary → Collibra Protect dataLocation constraint set to the deployment's tenant-asset-domain identifier; an evaluation against an asset outside that domain returns Phase-2 deny with obligation egress_outside_tenant_denied.

data_constraints.no_retraining → Collibra Protect rule label no-train; the Phase-2 verdict carries obligation no_retraining_required for any action whose operations set includes train or derive.

Reconciliation rule — Catalog vs. Protect vs. Data Quality vs. Lineage. Collibra's four modules are reconciled into a single Phase-2 verdict by the Data-PEP-side composer in this fixed order: Catalog (asset-existence) → Protect (policy-evaluate) → Data Quality (suppress action where DQ-score below deployment-declared floor) → Lineage (informative only; never deny). If any module returns deny, the composed verdict is deny. If any module returns constrain, the composed verdict is constrain with obligations from all constrain-returning modules merged by union. Otherwise permit. Collibra Workflow is out-of-scope for §7.1 (workflow-tooling boundary, §1.4.e).

§3.5 lineage source. `data.lineage_recorded.input_datasets` is populated from Collibra Lineage relations (`relationTypeId = 00000000-0000-0000-0000-000000007062` "is source of"); `output_artefact` is the Catalog asset URI of the derived asset registered by the Data-Runtime under the deployment's `gifo.outputs` domain.

7.2 Atlan

Phase-2 integration surface. Atlan active-metadata platform. The Data-PEP invokes:

POST `/api/meta/search/indexsearch` to resolve `dataset_scope` against Atlan asset GUIDs;

POST `/api/auth/policy/evaluate` (Atlan Personas + Purposes evaluation surface) to obtain the row/column / masking verdict;

POST `/api/meta/lineage/list` to resolve input-dataset references for §3.5.

Authentication is bearer-token under an Atlan API token issued to a deployment-controlled service-account user whose Personas membership is restricted to `gifo-data-pep`.

Projection rules.

`dataset_scope` → Atlan asset-glob expressed as an `IndexSearch` DSL query.`bool.must` clause: `{ "term": { "qualifiedName.text": "default/snowflake/.../customers/*" } }` with classification exclusions as `must_not` clauses on `__classificationsText`.

`purpose` → Atlan native Purpose object (Atlan's own term-of-art). The deployment's purpose vocabulary is registered as Atlan Purposes under workspace `gifo`; the Data-Mandate purpose string projects 1:1 onto the Atlan Purpose name field. This is the only §7 substrate where the projection is lossless because Atlan's own primitive carries identical semantics.

`operations` → Atlan Persona + Purpose permissionGroups (select, aggregate, update, share, etc.).

`data_constraints.tenant_egress_boundary` → Atlan Purpose domainBoundary attribute; cross-domain projection returns Phase-2 deny with `egress_outside_tenant_denied`.

`data_constraints.no_retraining` → Atlan custom-metadata field `gifo.noTrain = true`; Phase-2 verdict carries `no_retraining_required`.

Reconciliation rule — Personas vs. Purposes. Atlan exposes two parallel attribution surfaces: the requester-side Persona (who) and the request-side Purpose (why). Both must permit for Atlan to permit. If a Persona-side rule denies an action that the Purpose-side rule would otherwise permit, the Phase-2 verdict is deny and the Phase-1

reconciliation per §2.5.c yields deny (more-restrictive-wins). Where both sides return constrain, obligations are merged by union.

§3.5 lineage source. Atlan Lineage API response (relations[].typeName == "Process" edges) populates input_datasets; output_artefact is the Atlan GUID of the derived asset registered under the gifo workspace.

7.3 Informatica

Phase-2 integration surface. Informatica Intelligent Data Management Cloud (IDMC). The Data-PEP invokes:

GET /access/2/catalog/data/objects (EDC) to resolve dataset_scope against catalogue object IDs;

POST /mdm/v3/api/records/search (MDM) to obtain golden-record context where the proposed action targets a master entity;

POST /claire/v1/classifications/evaluate (CLAIRE) to obtain the sensitivity-classification verdict and the recommended masking obligations.

Authentication is IDMC session-id obtained via POST /saas/public/core/v3/login with deployment-controlled service-account credentials.

Projection rules.

dataset_scope → EDC objectSearchCriteria expression naming the EDC resource ID and an optional facet filter on the core.classification attribute.

purpose → IDMC Custom Attribute gifo.purpose registered on EDC catalogue objects; the Phase-2 evaluation rejects any object whose declared purpose-allow-list does not include the Data-Mandate purpose.

operations → IDMC Data Access Management permission set (READ, AGGREGATE, WRITE_BACK, EXPORT).

data_constraints.tenant_egress_boundary → IDMC Secure Agent group identifier; Phase-2 returns deny with egress_outside_tenant_denied for export operations targeting agents outside the declared group.

data_constraints.no_retraining → CLAIRE classification tag noModelTraining; surfaced as Phase-2 obligation no_retraining_required.

Reconciliation rule — EDC vs. MDM vs. CLAIRE. Three-module reconciliation by deployment-declared priority, with the default ordering CLAIRE > EDC > MDM (more-restrictive-wins): if CLAIRE classifies the dataset as denying for the proposed purpose, the Phase-2 verdict is deny regardless of EDC permission state. If CLAIRE permits and EDC permits but MDM golden-record context indicates the entity is under a hold (e.g. a

regulatory freeze flag), the Phase-2 verdict is deny with diagnostic obligation `mdm_record_hold`. If all three permit, the Phase-2 verdict is permit with merged obligations. Informatica Axon Data Governance is out-of-scope for §7.3 (separate workflow surface).

§3.5 lineage source. EDC Lineage API (`/access/2/catalog/data/lineage`) populates `input_datasets`; `output_artefact` is the EDC object ID of the derived asset registered against the deployment's `gifo` resource.

7.4 IBM watsonx.data / Cloud Pak for Data

Phase-2 integration surface. IBM watsonx.data lakehouse + Cloud Pak for Data (CP4D) governance modules. The Data-PEP invokes:

POST `/v3/governance/policies/{policy_id}/evaluate` (Watson Knowledge Catalog — WKC) to obtain the policy verdict;

POST `/v1/data_protection_rules/evaluate` (CP4D Data Privacy) to obtain the row/column masking obligations;

GET `/lakehouse/api/v2/catalogs/{catalog_id}/schemas/{schema}/tables/{table}` (watsonx.data) to resolve `dataset_scope` against lakehouse table identifiers.

Authentication is IAM API key exchanged for a CP4D bearer token via POST `/icp4d-api/v1/authorize`; the bound service-id holds CP4D role Data Steward and watsonx.data role MetastoreAccess (read).

Projection rules.

`dataset_scope` → watsonx.data fully-qualified table identifier
`<catalog>.<schema>.<table>` plus WKC business-term filter on the `gifo.purpose-allow-list` custom relationship.

`purpose` → WKC business-term reference; the deployment's purpose vocabulary is registered as a WKC Category under category `gifo.purposes`.

`operations` → CP4D Data Privacy rule action enum (ALLOW, DENY, MASK, OBFUSCATE, REDACT).

`data_constraints.tenant_egress_boundary` → CP4D Project boundary identifier; cross-project export returns Phase-2 deny with `egress_outside_tenant_denied`.

`data_constraints.no_retraining` → CP4D Data Privacy rule label no-foundation-model-training; Phase-2 carries `no_retraining_required`.

Reconciliation rule — WKC vs. Data Privacy vs. watsonx.governance. Two evaluators run in parallel: WKC (policy verdict) and Data Privacy (data-protection rule verdict). If either returns deny, the Phase-2 verdict is deny. If either returns MASK/OBFUSCATE/REDACT,

the Phase-2 verdict is constrain with the corresponding masking obligation. watsonx.governance, where deployed, is consulted only to project model-related obligations (e.g. no_retraining_required for actions whose output feeds a watsonx.governance-tracked model); it does not override WKC or Data Privacy verdicts.

§3.5 lineage source. watsonx.data Iceberg snapshot manifest plus WKC Data Lineage records (/v3/lineage) populate input_datasets; output_artefact is the watsonx.data table identifier of the derived asset.

7.5 Microsoft Purview

Phase-2 integration surface. Microsoft Purview unified data-governance. The Data-PEP invokes:

POST /datamap/api/search/query?api-version=2023-09-01 (Purview Data Map) to resolve dataset_scope against catalogued asset GUIDs;

POST /policystore/dataPolicies/{policyName}/evaluate?api-version=2024-03-01 (Purview Data Policy) to obtain the row/column / classification verdict;

POST /dlp/api/policies/evaluate (Purview Data Loss Prevention) to obtain DLP-derived egress obligations;

GET /datamap/api/atlas/v2/lineage/{guid} to resolve input-dataset references for §3.5.

Authentication is Microsoft Entra OAuth2 client-credentials against the <https://purview.azure.net/>.default scope; the bound service principal holds Purview RBAC roles Data Curator and Policy Author.

Projection rules.

dataset_scope → Purview Data Map asset-search filter expressed as a keywords + filter query against entityType and assetTypes.

purpose → Purview Data Policy principalAttribute rule with attribute name gifo.purpose; the deployment's purpose vocabulary is registered as a Purview Glossary under glossary gifo.purposes.

operations → Purview Data Policy actionGrants (Read, Modify, Delete, Share).

data_constraints.tenant_egress_boundary → Purview DLP policy scope set to the deployment's Microsoft 365 tenant + Azure subscription identifiers; cross-tenant share returns Phase-2 deny with egress_outside_tenant_denied.

data_constraints.no_retraining → Purview classification MICROSOFT.PERSONAL.DO-NOT-USE-FOR-AI-TRAINING (or deployment-defined custom classification with equivalent semantics); surfaced as no_retraining_required.

Reconciliation rule — Data Map vs. Data Policy vs. DLP. Sequential composition: Data Map (asset-existence + classification fetch) → Data Policy (action grant evaluation) → DLP (egress-class actions only). If Data Policy returns deny, Phase-2 is deny. If DLP returns deny for an egress-class action, Phase-2 is deny with `egress_outside_tenant_denied`. If Data Policy returns permit with classification obligations attached, Phase-2 is constrain with the obligations. Composition with Microsoft Entra (CCPE-G axis) is the deployment's responsibility per §1.4.d; this cookbook addresses only the data-axis surface.

§3.5 lineage source. Purview Atlas Lineage API (`/datamap/api/atlas/v2/lineage/{guid}`) populates `input_datasets`; `output_artefact` is the Purview asset GUID of the derived asset registered through POST `/datamap/api/atlas/v2/entity`.

Family 2 — Access-Governance Overlays

7.6 Immuta (Canonical) — with Privacera as Alternative

Selection rationale. Immuta is the canonical access-governance overlay cookbook target. The selection criterion declared at v0.1 §7.6 was the platform's native expressiveness for purpose-bound policy and its API maturity for the §4.3 Phase-2 capability contract. Immuta is selected on three grounds: (i) Immuta exposes a first-class native primitive named Purpose with its own lifecycle, attribute model, and policy-binding surface, providing a near-lossless projection for the Data-Mandate purpose field that no other §7 substrate matches at this level of native fidelity (Atlan's Purposes construct is comparably named but oriented to attribute-bundles rather than processing-intent); (ii) Immuta's Policy Decision API exposes a synchronous evaluation endpoint suitable for direct Phase-2 invocation by the Data-PEP without intermediate planning steps; (iii) Immuta's Project construct offers a deployment-controlled tenant-egress boundary that maps cleanly onto `data_constraints.tenant_egress_boundary`. Privacera remains an equally legitimate access-governance overlay choice and is referenced as the alternative cookbook below; deployments selecting Privacera follow §7.6 with the substitutions enumerated under "Privacera alternative".

Phase-2 integration surface (Immuta canonical). Immuta Data Security Platform. The Data-PEP invokes:

POST `/governance/v2/purposes/{purposeId}/evaluate` (Immuta Purpose evaluation) to obtain the purpose-bound verdict;

POST `/policy/v2/evaluate` (Immuta Policy Decision API) to obtain the row/column / masking verdict bound to the active Immuta Project;

GET `/audit/v2/queries` to obtain the overlay's own audit-trail correlation IDs for cross-reference into the §3.4 stream.

Authentication is Immuta API key bound to a deployment-controlled service account whose role is Governance (read) plus Project Member of the deployment's gifo Project.

Projection rules.

dataset_scope → Immuta Data Source URN plus an optional Project subscription filter; scope clauses with classification exclusions project to Immuta Tag-based subscription-policy must_not filters.

purpose → Immuta native Purpose object (1:1, lossless projection — same as Atlan §7.2 but Immuta's primitive is purpose-binding-first whereas Atlan's is access-bundle-first). The deployment's purpose vocabulary is registered as Immuta Purposes via POST /governance/v2/purposes.

operations → Immuta Subscription-Policy action set (SELECT, INSERT, UPDATE, DELETE, SHARE).

data_constraints.tenant_egress_boundary → Immuta Project membership boundary; an evaluation invoking a data source outside the bound Project returns Phase-2 deny with egress_outside_tenant_denied.

data_constraints.no_retraining → Immuta Data-Policy custom action restriction restrict-action: model-train; Phase-2 carries no_retraining_required.

Reconciliation rule — Purpose-evaluation vs. Policy-evaluation. Both endpoints run in sequence: Purpose-evaluation first, then Policy-evaluation. If Purpose-evaluation denies, the Phase-2 verdict is deny and Policy-evaluation is not invoked (saves Immuta API budget). If Purpose-evaluation permits and Policy-evaluation returns row/column-level masking, Phase-2 is constrain with the masking obligations carried verbatim into the §3.3 Decision Envelope. Where both return permit unconditionally, Phase-2 is permit. Immuta's own audit stream is Not a substitute for the §3.4 stream; the deployment's Console Must persist its own audit events with cross-reference correlation IDs from GET /audit/v2/queries.

§3.5 lineage source. Immuta records the policy-decision context but does not produce dataset-level lineage; the Data-Runtime emits data.lineage_recorded from its own query-engine instrumentation (typical hosts: Snowflake, Databricks, Starburst Trino) and references the Immuta policy-decision correlation ID in the obligations_honoured array.

Privacera alternative. A deployment selecting Privacera in lieu of Immuta substitutes the following surfaces: Immuta Purpose-evaluation API → Privacera PolicySync attribute-evaluation endpoint (POST /policysync/v1/evaluate); Immuta Policy Decision API → Privacera Apache Ranger-derived row/column/masking evaluation; Immuta Project → Privacera Application boundary. The Data-Mandate purpose field projects onto a Privacera Tag-attribute gifo.purpose (lossy projection — Privacera does not carry a first-class Purpose primitive at v0.2 publication; this is the substantive grounds on which

Immuta was chosen as canonical). All other reconciliation and lineage rules are identical to the Immuta cookbook above.

Family 3 — Platform-Native Catalogues

7.7 Databricks Unity Catalog

Phase-2 integration surface. Databricks Unity Catalog. The Data-PEP invokes:

GET /api/2.1/unity-catalog/tables/{full_name} and GET /api/2.1/unity-catalog/schemas to resolve dataset_scope against the three-level namespace <catalog>.<schema>.<table>;

POST /api/2.1/unity-catalog/permissions/{securable_type}/{full_name} (effective-permissions check) to obtain the Phase-2 grant verdict;

GET /api/2.0/lineage-tracking/table-lineage to resolve input-dataset references for §3.5;

POST /api/2.0/sql/statements (SQL Warehouse) for SQL-level row-filter / column-mask evaluation expressed via Unity Catalog Row Filter and Column Mask functions.

Authentication is Databricks personal access token (PAT) or OAuth2 machine-to-machine token bound to a deployment-controlled service principal with Unity Catalog metastore role READ_VOLUME, USE_CATALOG, USE_SCHEMA, SELECT (on declared dataset-scope subset).

Projection rules.

dataset_scope → Unity Catalog three-level-namespace glob, e.g.

acme_warehouse.customers.*; classification exclusions project to Unity Catalog Tag exclusions (e.g. WHERE NOT __databricks_internal.tag_value('PII', 'true')).

purpose → Unity Catalog Tag with key gifo.purpose applied to the schema or catalog level; the Data-PEP queries tag_assignments and rejects any dataset whose gifo.purpose-allow-list tag does not include the Data-Mandate purpose.

operations → Unity Catalog SQL grants (SELECT, MODIFY, EXECUTE, CREATE, USAGE).

data_constraints.tenant_egress_boundary → Unity Catalog metastore boundary; Delta Sharing requests targeting recipients outside the metastore return Phase-2 deny with egress_outside_tenant_denied.

data_constraints.no_retraining → Unity Catalog Tag gifo.no-train = true plus Mosaic AI Gateway policy where present; surfaced as no_retraining_required.

Reconciliation rule — Unity Catalog grants vs. Workspace permissions vs. Row Filter / Column Mask. Unity Catalog grants are authoritative; legacy Databricks Workspace permissions are consulted only as a constraint floor (Workspace deny overrides Unity

permit, but Workspace permit does not override Unity deny). Row Filter and Column Mask UDFs are evaluated server-side at SQL execution and surfaced into the Phase-2 verdict as constrain obligations. Reconciliation with Databricks Genie / agent surfaces is out-of-scope for §7.7 in v0.7 (separate agent-side surface; tracked at §13.j).

§3.5 lineage source. Unity Catalog Lineage Tracking API (/api/2.0/lineage-tracking/table-lineage) populates input_datasets; output_artefact is the three-level-namespace identifier of the derived table registered through CREATE TABLE or CREATE VIEW. Lineage emission boundary is the SQL Warehouse for SQL-class operations and the compute-cluster for notebook-class operations; the Data-Runtime composer normalises both into the §3.5 envelope.

7.8 Snowflake Horizon

Phase-2 integration surface. Snowflake Horizon governance suite. The Data-PEP invokes:

SELECT ... FROM SNOWFLAKE.ACCOUNT_USAGE.OBJECT_TAGS and SELECT SYSTEM\$GET_TAG('gifo.purpose-allow-list', '<object>', 'TABLE') to resolve dataset_scope and tag-allow-list state;

SELECT POLICY_REFERENCES(POLICY_NAME => 'gifo_purpose_policy') to enumerate the Row Access and Masking Policies attached to scope-resolved objects;

SELECT ... FROM SNOWFLAKE.ACCOUNT_USAGE.ACCESS_HISTORY and SELECT ... FROM SNOWFLAKE.ACCOUNT_USAGE.OBJECT_DEPENDENCIES to resolve input-dataset references for §3.5;

POST https://<account>.snowflakecomputing.com/api/v2/statements (Snowflake SQL API) for synchronous policy-evaluation invocation.

Authentication is Snowflake key-pair authentication bound to a service-role-assigned user; the bound role holds privileges USAGE on warehouse, USAGE on database/schema, SELECT on declared dataset-scope subset, APPLY MASKING POLICY.

Projection rules.

dataset_scope → Snowflake fully-qualified object identifier
<database>.<schema>.<object>; classification exclusions project to Tag-based filters using the SYSTEM\$GET_TAG predicate.

purpose → Snowflake Tag gifo.purpose applied at schema or database level with allow-list enumerated; Masking Policies and Row Access Policies attached to a tagged object Must include a current_tag('gifo.purpose-allow-list') predicate that admits the Data-Mandate purpose.

operations → Snowflake SQL privileges (SELECT, INSERT, UPDATE, DELETE, OWNERSHIP, USAGE).

data_constraints.tenant_egress_boundary → Snowflake Account boundary; Cross-Cloud Replication and Secure Data Sharing targeting outside-account consumers return Phase-2 deny with egress_outside_tenant_denied.

data_constraints.no_retraining → Snowflake Tag gifo.no-cortex-train = true honoured by the Data-Runtime when invoking Cortex AI / Cortex Search functions; surfaced as no_retraining_required.

Reconciliation rule — Tag-based masking vs. Row Access Policies vs. Data Classification. Snowflake evaluates all three server-side at query-compile time; their composition is more-restrictive-wins (Snowflake's native semantics). The Data-PEP receives the composed verdict via the SQL API response. Where Data Classification surfaces a sensitivity-derived obligation that the Data-Mandate's purpose does not cover, Phase-2 returns constrain with the recommended masking. Snowflake Trust Center compliance posture is consulted asynchronously for non-blocking obligations (e.g. flag-only audit annotations) and Must Not block Phase-2 evaluation. Native Cortex agent / function calls as Data-Runtime hosts is treated as a deployment-side composition: the Data-PEP wraps Cortex invocations in the same Phase-1 → Phase-2 chain.

§3.5 lineage source. Snowflake ACCESS_HISTORY and OBJECT_DEPENDENCIES populate input_datasets; output_artefact is the fully-qualified identifier of the derived table / view / share. Lineage events latency is bounded by Snowflake's ACCOUNT_USAGE propagation (≤ 45 minutes at v0.2 publication); the Data-Runtime composer Must carry the action's own correlation ID at emission and accept that the platform-side ACCESS_HISTORY row may arrive later than data.lineage_recorded.

7.9 AWS Lake Formation / Glue Data Catalog

Phase-2 integration surface. AWS Lake Formation tag-based access control + AWS Glue Data Catalog. The Data-PEP invokes:

glue:GetTable, glue:GetDatabase, glue:SearchTables to resolve dataset_scope against the Glue Data Catalog database/table identifiers;

lakeformation:GetResourceLFTags and lakeformation:GetEffectivePermissionsForPath to obtain the LF-Tag-attached policy state;

lakeformation:GetTemporaryGlueTableCredentials (for actual data access) to obtain scoped-down session credentials whose Phase-2 verdict is the credential-issuance success / failure plus any data-filter expression returned;

lakeformation:GetDataLakeSettings for cross-account boundary state;

AWS CloudTrail Data Events on Lake Formation as the §3.5 lineage source.

Authentication is AWS IAM role (sts:AssumeRole) bound to a deployment-controlled service role whose Lake Formation grants are scoped to the declared dataset-scope subset.

Projection rules.

dataset_scope → Glue catalogue <database>.<table> identifier filtered by LF-Tag predicates ({ "TagKey": "gifo.scope", "TagValues": ["customers"] }); classification exclusions project to LF-Tag exclusion predicates.

purpose → LF-Tag with key gifo.purpose applied at the database or table level; the Data-PEP rejects any object whose gifo.purpose-allow-list LF-Tag does not include the Data-Mandate purpose.

operations → Lake Formation permission set (SELECT, INSERT, DELETE, DROP, ALTER, DESCRIBE).

data_constraints.tenant_egress_boundary → AWS Account boundary plus Lake Formation cross-account grant state; cross-account lakeformation:GetTemporaryGlueTableCredentials outside the bound account returns Phase-2 deny with egress_outside_tenant_denied.

data_constraints.no_retraining → LF-Tag gifo.no-train = true honoured by Bedrock / SageMaker Data-Runtime hosts; surfaced as no_retraining_required.

Reconciliation rule — LF-Tags vs. Glue catalogue grants vs. Data Filter. Lake Formation LF-Tag-based access control and named-resource grants are evaluated additively by Lake Formation itself; the Data-PEP receives the composed verdict from GetEffectivePermissionsForPath. Data Filters (row/column-level filters) are surfaced as constrain obligations and applied server-side by Athena / EMR / Redshift Spectrum at query execution. Multi-account / multi-region cross-account Phase-2 invocation is handled by issuing the Phase-2 query against the data-owning account's Lake Formation endpoint and propagating the verdict back through the Data-PEP. Composition with AWS IAM Identity Center (CCPE-G axis) is the deployment's responsibility per §1.4.d.

§3.5 lineage source. AWS CloudTrail Data Events on Lake Formation (lakeformation:GetTemporaryGlueTableCredentials, glue:GetTable) plus optional AWS Glue Lineage (where the deployment runs Glue ETL jobs that emit lineage) populate input_datasets; output_artefact is the Glue table identifier of the derived asset registered through glue:CreateTable.

7.10 Cookbook Extension Hook

A deployment that selects a Phase-2 back-end not covered by §7.1–§7.9 Must publish a cookbook entry following the same shape (integration surface / GAuth touchpoints / open questions) and register the cookbook reference in the Console. The published cookbook entry is the §4.5 conformance anchor for that deployment.

8. References

8.1 Normative References

GiFo-RFC 0090 (Rights in Contributions); GiFo-RFC 0110 (GAuth Protocol Engine); GiFo-RFC 0111 (GAuth Authorization Framework); GiFo-RFC 0115 v2.2 (Power-of-Attorney Credential Definition); GiFo-RFC 0116 (Extended Token / W3C VC Representation); GiFo-RFC 0117 (PEP Interface); GiFo-RFC 0118 (Management API); GiFo-RFC 0125 SDK v0.93+ (GAuth Open-Core SDK — slot-registry implementation discipline); GiFo-RFC 0140 v1.2 (G-Audit Profile — `phase2\_evaluation.profile` partitioning key origin); GiFo-RFC 0160 (G-Audit Profile — audit-event payload baseline); BCP 14 (RFC 2119, RFC 8174); RFC 7515 (JWS); RFC 7517 (JWK); RFC 8785 (JSON Canonicalization Scheme, JCS) — normative anchor for §6.2.

8.2 Informative References

GiFo-RFC 0150 (CCPE-B / G-PaC) — informative cross-reference for the dual-path Data-PDP architecture at §13.A.7 (PEP Phase-2 extension point precedent at RFC 0150 §4.3.A); GiFo-RFC 0170 v0.9.1 (CCPE-F / G-Commerce) — structural-symmetry reference for the front matter, §2 architecture, §3 envelope, §6 cryptographic baseline, and the §13.A-equivalent slot-registry foundation against `commerce\_pdp` / `commerce\_authority`; GiFo-RFC 0210 v0.7 (CCPE-G / G-IBE) — structural-symmetry reference for the §1.4 boundary register, §1.5 normative-exclusion shape, the catalogue-and-prescribe posture, and the §13.A foundation against `identity\_platform` / `identity\_bridge`; IETF RFC 2753 (Framework for Policy-based Admission Control — origin of Policy*Point and the PDP/PEP split inherited by §2.4 / §2.5); NIST SP 800-207 (Zero Trust Architecture — origin of the per-action authorisation discipline); NIST AI Risk Management Framework v1.0 — MAP function as the natural cross-walk anchor for purpose-fit verification (in-body summary at §11; formal sub-category cross-walk at Appendix A); EU Regulation (EU) 2024/1689 — EU AI Act; EU Regulation (EU) 2016/679 — GDPR (purpose-limitation principle as background context for the §3.1 purpose field); `docs/CONNECTOR\_SLOT\_FOUNDATION.md` (descriptive companion document — open-core foundation contract spanning all 13 slots; informative input to §13.A).

9. Conformance Levels and Reservations

A deployment claims G-Data Conformance if and only if it satisfies the §4.5 conformance checklist in full. A deployment is non-conformant to G-Data if it operates any of the §4.6 CCPE-H-NCI / NCP / NCO variants.

Two additional optional badges are reserved for v1.0:

- CCPE-H Strict (reserved) — adds the ≤ 1 s revocation-tolerance ceiling on §3.2 cascade; the ≤ 1 s parent-chain-state staleness per §3.1.1; the ≤ 750 ms phase2_timeout_ms per §3.1.2; mandatory lineage-attestation signature attestation; and the §6.1 / §6.4 / §6.7 Strict signature-algorithm, key-rotation, and replay-skew overrides.
- CCPE-H Behörde (reserved) — calibrated to the EU AI Act high-risk-system supervisory framework and the German BSI Grundschutz baseline; Behörde-specific signature-algorithm overrides per §6.1; ≤ 1 s parent-chain-state staleness with audit-bound time-source attestation per §3.1.1; ≤ 500 ms phase2_timeout_ms per §3.1.2.

9.1 Reservations Catalogue

Identifier	Kind	Reservation
ccpe_h_purpose_binding	Decision-Envelope obligation code	Reserved by Foundation; carries the result of the §2.5.a purpose-fit check and Must appear in the obligations array of every Phase-1 Decision Envelope where the purpose-fit check materially shaped the verdict.
lineage_attestation_required	Decision-Envelope obligation code	Reserved; signals that the action's permission is conditional on the §3.5 emission.
egress_outside_tenant_denied	Decision-Envelope obligation code	Reserved; signals that an egress operation was constrained by the Data-Mandate's data_constraints.tenant_egress_boundary.
no_retraining_required	Decision-Envelope obligation code	Reserved; signals that the action carries a downstream no_retraining obligation honoured by any consumer of the output artefact.
parent_chain_invalid	Decision-Envelope obligation code	Reserved; signals §3.2 / §3.1.1 violation.

mandate_already_consumed Decision-Envelope obligation
code Reserved; signals single-use mandate replay
attempt.

phase2_unreachable Decision-Envelope obligation code
Reserved; signals §2.5.c fail_disposition activation.

audit_persistence_required Decision-Envelope obligation
code Reserved; signals that the persistence-before-
stream invariant (§3.4) gates further processing.

ccpe_h_scenario Audit-trail field Reserved by
Foundation; carries the §2.6 deployment-scenario value S1 | S2
| S3 on the wire. Must be populated on every §3.4 audit event.
A §4.5 conformance claim is rejected if ccpe_h_scenario != S2
per §4.5a.

Audit-tag prefix ccpe-h-* Audit-trail
phase2_evaluation.profile namespace Reserved by Foundation;
non-conformant variants take ccpe-h-nci-* / ccpe-h-ncp-* /
ccpe-h-nco-* per §4.6.

data_pdp Slot identifier (Type-A, multi-instance)
Reserved by §13.A.2 for the Data-PDP slot.

data_authority Slot identifier (Type-B, single-instance)
Reserved by §13.A.3 for the Data-Authority slot.

data.action_decided.metered Audit event type
Reserved by §13.A.5; emitted by `recordDataDecision()` per
§6.5a.2.

data.lineage_attestation.recorded Audit event type
Reserved by §13.A.5; emitted by `recordLineageAttestation()`
per §6.5a.3.

data-default / data-strict / data-behoerde Conformance
disposition hints Reserved by §13.A.6 for the per-instance
`conformanceDispositionHint` field.

ccpe-h / ccpe-h-nci / ccpe-h-ncp / ccpe-h-nco
`phase2\_evaluation.profile` values Reserved by §15.3.

unknown_platform_id_fail_closed /
user_self_hosted_zero_variable / tariff_o_non_billable
`MeteringResult.reason` values Reserved by §6.5a.2
(invariants (1), (2), (3)). Each value is mandated as a
recorder return per the v0.5.1 reason-population tightening;
the customer-facing reason vocabulary is exhaustively listed
here and does not surface internal-tier internals.

10. CCPE Family Lineage (Informative)

This RFC inherits the architectural-pattern lineage shared across the CCPE family — three-service Console / Authority / [domain]-Runtime split; bipolar credential-bound + platform-bound enforcement; mandate envelope shape; non-conformant-variant taxonomy convention; verdict vocabulary {permit, deny, constrain} plus separate obligations array; persistence-before-stream invariant; RFC 8785 JCS canonicalisation; TLS 1.3 + mutual-auth transport baseline. The family members are RFC 0140 (CCPE-A / G-AGT), RFC 0150 (CCPE-B / G-PaC), RFC 0160 (CCPE-C / G-Com), RFC 0170 (CCPE-F / G-Commerce), RFC 0180 (CCPE-D / G-Code), RFC 0210 (CCPE-G / G-IBE), and RFC 0420 (CCPE-E / G-IoT). CCPE-H is the eighth profile and the second occupant of the GiFo-RfC 016x neighbourhood (alongside RFC 0160).

No sibling profile is a normative dependency of this RFC. The structural symmetry with RFC 0170 v0.9.1 (front matter shape, §2 / §3 / §6 layout) and RFC 0210 v0.7 (the §1.4 boundary register pattern, the catalogue-and-prescribe posture, the §1.5 normative-exclusion shape) is the deliberate authorial choice supporting cross-family auditability.

11. NIST Cross-Walk — AI RMF MAP Function (Informative)

This in-body cross-walk gives a one-paragraph orientation to the NIST AI Risk Management Framework v1.0 MAP function as it relates to CCPE-H. The MAP function is the first of the four AI RMF core functions (MAP, MEASURE, MANAGE, GOVERN) and is concerned with establishing the context and characterizing the AI system's intended purpose, deployment context, knowledge limits, third-party dependencies, and impact landscape. CCPE-H addresses the data-authorization slice of MAP: the §3.1 Data-Mandate envelope normatively names the purpose (MAP 1.1), the dataset-scope (MAP 3.3), the operations enumeration (MAP 2.1), and the data constraints (MAP 1.6); the §3.4 / §3.5 audit and lineage trail provides the substrate against which MEASURE-class evaluation can be performed; and the §13.A.6 Strict / Behörde conformance-disposition vocabulary is the mechanism by which a deployment can claim a higher-oversight profile (MAP 3.5).

The formal sub-category-level cross-walk — naming for each of the 18 MAP sub-categories either the CCPE-H normative surface that addresses it or an explicit out-of-scope-with-indirect-support disposition — is published at Appendix A. §11 retains this in-body summary for readers who want the orientation; Appendix A is the authoritative table for downstream consumers (NIST NCCoE Cyber AI Profile reviewers; MEASURE/MANAGE/GOVERN cross-walk authors) who need to walk the AI RMF MAP function against the CCPE-H surface line by line.

The MEASURE and MANAGE functions of the NIST AI RMF intersect with CCPE-H peripherally at the §3.4 / §3.5 audit and lineage layers but are not cross-walked at this version. The GOVERN function is engaged by CCPE-H only insofar as the deployment's purpose vocabulary registration in the Console (§3.1, §3.1.3) is itself a governance artefact; deeper GOVERN cross-walk is deferred. Companion appendices for MEASURE / MANAGE / GOVERN are tracked at §13(y) for sequencing across future versions of this RFC.

12. Acknowledgements

The Architecture Working Group thanks the data-platform-vendor reviewers and the open-core implementers whose comments produced the §13.A foundation incorporated here. The descriptive companion document ``docs/CONNECTOR_SLOT_FOUNDATION.md`` — capturing the foundation contract that already governs all 13 slots in the GAuth open-core implementation — provided the working checklist of divergence points against which the §13.A normative content is calibrated. The NIST NCCoE Cyber AI Profile §33 outreach trail provided the pacing for the Appendix A NIST AI RMF MAP cross-walk closure carried into this version.

13. Open Issues

- a. Open — JSON-Schema / CDDL formalisation of §3.1 Data-Mandate envelope and §3.3 Decision Envelope.
- b. Open — PQC migration for the §6.1 signature algorithms (open-core scope; the Legal Notice's commercial PQC carve-out is orthogonal per §1.5).
- c. Open — Strict and Behörde profile bodies (§9 reserves the badges).
- d. Open — Regulator-bound audit-export format for the §3.4 / §3.5 streams, calibrated to EU AI Act high-risk-system supervisory expectations.
- e. Open — Composition guidance with CCPE-G (RFC 0210) where the deployment operates both profiles.
- f. Open — Cookbook entry for additional substrates surfaced through client engagement (§7.10 extension hook); includes Databricks Genie / agent surfaces noted at §7.7.
- g. Open — Treatment of streaming / event-sourced data-platform substrates (Kafka with Confluent governance; Flink).
- h. Open — Generalisation of per-instance scenario tagging (``ccpe_h_scenario``) to other multi-instance slots (``identity_platform``, ``commerce_pdp``); awaits coordination with RFC 0210 v0.8+ and RFC 0170 v0.9.x+.

- i. Open — Formal `TariffSlotAvailability` seven-value vocabulary normative reservation (currently descriptive at companion-document §5; v0.7 reserves only the four values needed by §13.A.1).
- j. Open — Generalisation of duck-type-guard declaration to other slots in `ConnectorSlotConfig` (§13.A.3).
- k. Open — Slot-deprecation lifecycle mechanics for the `deprecated` / `sunset_at` reservation at §13.A.6.
- l. Open — Purpose Vocabulary Registry lifecycle (§3.1.3 reserves only the registration-presence-at-issuance obligation; CRUD surface, audit-event taxonomy for vocabulary mutations, multi-tenant scoping, case-folding / length / reserved-prefix conventions, and cross-deployment portability of vocabulary identifiers remain deferred).
- m. Open — Companion-document absorption-vs-version-pin: whether the descriptive `docs/CONNECTOR_SLOT_FOUNDATION.md` foundation-contract content is absorbed into a future §13.A normative body, or whether §13.A pins to a specific versioned snapshot of the companion.
- n. Open — Slot-#1–#11 normative-ownership coordination (§13.A.1a): codification of slot numbers by the responsible RFCs (GAAuth core for slots #1–#7; RFC 0170 for #8–#9; RFC 0210 for #10–#11) and corresponding migration of the slot-number-ownership column from "Companion (descriptive)" to "RFC (normative)".

13.A GAAuth Open-Core Reference Connector Slot Registry (Normative)

This subsection specifies the reference connector-slot-registry foundation that the GAAuth Open-Core SDK at v0.93+ realises and that any compatible Foundation-side reference operator (e.g., Gimel Auth) Must adopt for the data-axis slots. The intent is to provide a single, normatively-named integration surface against which Data-PDP adapters (Type-A) and Data-Authority adapters (Type-B) are registered, and against which the open-core symmetry rules of §6.5a are enforced.

Compatibility note. §13.A is a structural sibling of RFC 0210 v0.7 §13.A (which names the `identity_platform` and `identity_bridge` slots) and of the equivalent §13.A-shape foundation in RFC 0170 v0.9.1 (which names the `commerce_pdp` and `commerce_authority` slots). The three foundations share the tariff matrix vocabulary, the open-core symmetry invariants, the audit-event taxonomy convention, and the multi-instance semantics. Where an implementation realises all three foundations in the same process (the canonical case for Gimel Auth), the foundations compose into a single 13-slot registry surface as described in `docs/CONNECTOR_SLOT_FOUNDATION.md`.

(Companion-document status.) The descriptive companion document ``docs/CONNECTOR_SLOT_FOUNDATION.md`` referenced throughout §13.A remains descriptive (not normative) at v0.7. Whether the companion document's foundation-contract content is absorbed into a future §13.A normative body, or whether §13.A pins to a specific versioned snapshot of the companion, is tracked as an open item at §13(u).

13.A.1 The Two Data-Axis Slots and the Tariff Matrix

The reference operator Must expose the following two connector slots dedicated to the data-axis. (These slots are #12 and #13 in the canonical 13-slot registry described by the foundation companion document; slots #1–#11 are introduced normatively by other RFCs — see §13.A.1a for the cross-registry status table.)

#	Slot identifier	Type	Instance cardinality
	Tariff-availability at Tariff S/M/L	O	Tariff-availability at Tariff
12	data_pdp (one adapter per platformId)	A	multi (one adapter per user_provided_required gimel_or_user
13	data_authority gimel_or_user	B	single null_or_user

Vocabulary distinction (Normative). The matrix cells above name ``TariffSlotAvailability`` values per §15.2 — they describe what kinds of provisioning are permitted at this tariff, not the per-instance ``operatorMode`` of any individual registration. The two vocabularies are disjoint: a ``TariffSlotAvailability = gimel_or_user`` cell admits per-instance ``operatorMode ∈ {gimel_managed, user_provided}``; a ``TariffSlotAvailability = user_provided_required`` cell admits per-instance ``operatorMode ∈ {user_provided, user_self_hosted}`` (and forbids ``gimel_managed`` per §13.A.4 open-core operator-mode guard); a ``TariffSlotAvailability = null_or_user`` cell admits the slot remaining null (no registration) or per-instance ``operatorMode ∈ {user_provided, user_self_hosted}``. The reference operator's registration validator Must enforce this mapping at registration time and Must reject any registration whose ``operatorMode`` is not admitted by the cell's ``TariffSlotAvailability`` value at the configured ``tariffTier``.

The matrix mirrors the equivalent matrices for ``commerce_pdp`` / ``commerce_authority`` (RFC 0170 v0.9.1) and ``identity_platform`` / ``identity_bridge`` (RFC 0210 v0.7 §13.A.1) by deliberate structural symmetry.

13.A.1a Slot-Number Allocation Across the Open-Core Registry (Normative)

The 13-slot canonical registry surface composed across the open-core foundations is anchored as follows. The status of each slot is split into two explicit dimensions: identifier-ownership (which RFC normatively owns the slot identifier and the typed adapter contract) and slot-number-ownership (which artefact is the current authoritative anchor for the slot number).

#	Slot identifier	Identifier-ownership
	Slot-number-ownership	
1	authority 0117) at protocol-level vocabulary	GAuth core (RFC 0110 / 0111 / 0115 / Companion (descriptive)
2	resource_owner Companion (descriptive)	GAuth core (as above)
3	client_owner Companion (descriptive)	GAuth core (as above)
4	client Companion (descriptive)	GAuth core (as above)
5	resource_server Companion (descriptive)	GAuth core (as above)
6	owner_authorizer Companion (descriptive)	GAuth core (as above)
7	client_authorizer Companion (descriptive)	GAuth core (as above)
8	commerce_pdp Companion (descriptive)	RFC 0170 v0.9.1 §13.A-equivalent
9	commerce_authority Companion (descriptive)	RFC 0170 v0.9.1 §13.A-equivalent
10	identity_platform Companion (descriptive)	RFC 0210 v0.7 §13.A
11	identity_bridge Companion (descriptive)	RFC 0210 v0.7 §13.A
12	data_pdp This RFC §13.A.1 (normative)	This RFC §13.A.2 (normative)
13	data_authority This RFC §13.A.1 (normative)	This RFC §13.A.3 (normative)

Column semantics (Normative). "GAuth core (...) at protocol-level vocabulary" means the slot identifier draws conceptually on the vocabulary established by the cited core RFCs at the protocol level; what is awaited for slots #1–#7 is a §13.A-equivalent slot-registry foundation that codifies the slot number and the slot-registry framing. "RFC

0170 / 0210 §13.A-equivalent" means the responsible RFC publishes a §13.A-equivalent foundation that names the slot identifier, the type (A/B), and the instance cardinality; the slot number itself remains companion-anchored until the responsible RFC codifies it.

"Companion (descriptive)" means ``docs/CONNECTOR_SLOT_FOUNDATION.md``

working numbering is the current authoritative anchor for the slot number. "This RFC (normative)" means both columns are claimed normatively by this RFC. Should a future revision of any other RFC codify a different slot number than the placeholder above, the reassignment is a registry-breaking change that Must be coordinated through the Architecture Working Group per §13(w). v0.7 commits no slot-number reassignment for any row.

13.A.2 Type-A (Multi-Instance) Slot — ``data_pdp``

(Adapter-interface notation. The ``DataPdp`` interface below and the ``DataAuthorityAdapter`` interface at §13.A.3 are TypeScript-flavoured pseudocode and are not normative TypeScript bindings. From-scratch implementations on alternative stacks (Go, Rust, Python; see §13.A.8) honour the contract by exposing the equivalent four operations through their host-language idiom.)

The ``data_pdp`` slot is multi-instance: the reference operator Must support concurrent registration of one adapter per externally-controlled ``platformId`` (e.g., ``snowflake-horizon-acme-prod``, ``databricks-unity-acme-eu``, ``immuta-saas-acme``, ``purview-acme-tenant``, ``lakeformation-acme-account-1234``). Each registration Must carry:

- ``platformId`` — string, deployment-controlled identifier;
- ``substrateFamily`` — one of ``catalogue`` (Collibra / Atlan / Informatica / IBM / Microsoft Purview), ``overlay`` (Immuta canonical / Privacera), or ``platform_native`` (Databricks Unity / Snowflake Horizon / AWS Lake Formation);
- ``cookbookSection`` — deployment-supplied free-text reference, not normatively resolved against §7. The field carries a string referencing the §7.x cookbook body (e.g., ``7.8.snowflake-horizon``); deployments using §7.10 extension hook supply the registered cookbook reference. The reference operator's registry Must Not validate the field's content against the §7 informative cookbook bodies; it is a registration-side documentation handle whose semantics are deployment-controlled. The §7.x identifier shape (the syntactic form of ``7.<n>.<slug`` and ``7.10:<extension-slug``) is reserved at §15.5 so that registrations across deployments share a stable identifier shape even though the content of the §7.x bodies remains informative;
- ``tariffTier`` — one of O / S / M / L per §15.1;
- ``operatorMode`` — one of ``gimel_managed`` / ``user_provided`` / ``user_self_hosted`` per §15.2; the value Must be admitted by the §13.A.1 matrix cell for (slot, tariffTier) per the vocabulary-distinction rule above;

- ``conformanceDispositionHint`` — one of ``data-default`` / ``data-strict`` / ``data-behoerde`` per §13.A.6;
- ``variantCode`` — one of ``ccpe-h`` / ``ccpe-h-nci`` / ``ccpe-h-ncp`` / ``ccpe-h-nco`` per §4.6 (carried on the wire as the ``phase2_evaluation.profile`` value);
- ``ccpe_h_scenario`` — explicit S1 / S2 / S3 per §2.6 (only S2 is conformant; S1 / S3 are in-scope but non-conformant per §4.5a);
- ``meteringLogCap`` — non-negative integer per §6.5a.4 (default 1 000); and
- a typed adapter conforming to the ``DataPdp`` interface:

```
interface DataPdp {  
    resolveScope(envelope: DataMandateEnvelope, scopeExpr:  
string): DatasetReference[];  
    evaluateAction(envelope: DataMandateEnvelope, action:  
ProposedAction): Phase2DecisionEnvelope;  
    cascadeRevocation(mandateId: string, reason: string):  
CascadeAck;  
    healthCheck(): HealthStatus;  
}
```

The reference operator's null implementation of ``DataPdp`` Must fail closed on ``evaluateAction`` and ``cascadeRevocation`` (returning a ``failClosed()`` error) per the no-mock policy — null adapters are placeholders, not silent successful no-ops.

The generic ``unregister(slotName)`` operation Must refuse multi-instance slots and require the caller to use the slot-specific ``unregisterDataPdp(platformId)`` operation. The aggregate operations ``healthCheckAll()``, ``getStatusSummary()``, ``isSlotActive()``, and ``getNullSlots()`` Must iterate ``data_pdp`` instances individually and aggregate the results.

Per-instance state: each instance carries its own ``registeredAt`` timestamp and ``lastHealthCheck``. Slot-level health is derived from the per-instance map via ``healthCheckDataPdp(platformId)`` (single-instance) and ``healthCheckAllDataPdps()`` (parallel fan-out reporting `{ healthyCount, totalCount, avgLatency }`). When the instance map is empty, the aggregate returns the slot's ``nullBehavior`` string as the ``details`` field.

13.A.3 Type-B (Single-Instance) Slot — `data\_authority`

The `data\_authority` slot is single-instance and conforms to the `DataAuthorityAdapter` interface (see the §13.A.2 adapter-interface notation note for the TS-flavoured-pseudocode caveat):

```
interface DataAuthorityAdapter {  
    issueDataMandate(envelope: DataMandateEnvelope):  
    IssuedMandate;  
  
    revokeDataMandate(mandateId: string, reason: string):  
    RevocationAck;  
  
    signLineageAttestation(event: LineageAttestationEvent):  
    SignedAttestation;  
  
    healthCheck(): HealthStatus;  
}
```

The reference operator's null implementation of `DataAuthorityAdapter` is registered by default at boot (single instance, default-null) and Must fail closed on `issueDataMandate` and `revokeDataMandate` per the no-mock policy. `signLineageAttestation` on the null adapter May return an unsigned acknowledgement; the recorder at §6.5a.3 emits the documented warning and proceeds with `signed: false`.

Duck-type guard (Normative). Because `DataAuthorityAdapter` shares the `ConnectorAdapter` union with otherwise-similar shapes, the registry Must apply a slot-specific duck-type guard at registration time:

```
if (slotName === "data_authority") {  
    const a = adapter as Partial<DataAuthorityAdapter>;  
    if (typeof a.signLineageAttestation !== "function" ||  
        typeof a.issueDataMandate !== "function" ||  
        typeof a.revokeDataMandate !== "function") {  
        return { success: false,  
            error: "Adapter does not satisfy  
DataAuthorityAdapter ..." };  
    }  
}
```

Generalisation of duck-type-guard declaration to other slots in `ConnectorSlotConfig` is open at §13(r).

13.A.4 Open-Core Symmetry Invariants

Both ``recordDataDecision()`` (§6.5a.2) and ``recordLineageAttestation()`` (§6.5a.3) Must apply strict open-core symmetry:

- Unknown identifier fails closed (foundation rule for any registry-coupled metering hook).
- ``operatorMode = "user_self_hosted"`` is never billable — Foundation operators incur zero variable cost on Tariff-O deployments.
- Tariff O coerces non-billable (warn for ``gimel_managed``).

These four invariants are the normative anchor of the open-core symmetry guarantee for the data-axis slots and are byte-for-byte identical to the equivalent invariants at RFC 0210 v0.7 §13.A.4 (``identity_platform`` / ``identity_bridge``) and at RFC 0170 v0.9.1's equivalent §13.A.4 (``commerce_pdp`` / ``commerce_authority``).

Open-core operator-mode guard (Normative). A reference operator Must treat ``gimel_managed`` + ``user_provided_required`` (i.e., a Tariff-O ``data_pdp`` registration whose ``operatorMode`` is ``gimel_managed``) as a hard registration-time error — the registration Must be refused with a structured error message naming the open-core invariant that was violated. The §6.5a.2(3) runtime warning entry for the same condition is a defence-in-depth fall-back that fires only if a refused-at-registration condition somehow exists at runtime (e.g., across a config import that bypassed the validator); the two layers are complementary, not contradictory. This closes foundation-contract §10 item 4.

13.A.5 Audit-Event Wiring

Every ``recordDataDecision()`` invocation that produces ``{ billable: true }`` (post-coercion) Must be persisted as a ``data.action_decided.metered`` audit event. Every ``recordLineageAttestation()`` invocation Must be persisted as a ``data.lineage_attestation.recorded`` audit event regardless of billable outcome. Both events are subject to the §3.4 persistence-before-stream invariant and Must carry the ``phase2_evaluation.profile`` partitioning key per §15.3.

Cascade events (``data.cascade.revoked``) that span multiple Data-PDPs Must carry ``phase2_evaluation.profiles[]`` (an array of ``{ platform_id, profile }`` mappings) instead of the singular ``phase2_evaluation.profile`` so that downstream audit consumers can partition by per-PDP ``ccpe-h`` variant. The cascade pattern is the canonical shape for any future cascade across a multi-instance slot (foundation-contract §8.3).

Singular-vs-plural mutual-exclusivity rule (Normative — restated from §15.3 for local readability). The two field shapes ``phase2_evaluation.profile`` and

``phase2_evaluation.profiles[]`` are mutually exclusive on a given audit event: a single-instance event Must carry the singular ``profile``; a multi-instance cascade event Must carry the plural ``profiles[]`` and Must Not carry the singular ``profile``; a downstream consumer Must treat the absence of the singular field on a cascade event as the documented cascade shape, not as a missing partitioning key.

Worked example (Informative) — ``phase2_evaluation.profiles[]`` cascade shape:

```
"phase2_evaluation": {  
  "profiles": [  
    { "platform_id": "snowflake-horizon-acme-prod", "profile":  
      "ccpe-h" },  
    { "platform_id": "databricks-unity-acme-eu", "profile":  
      "ccpe-h-nci" }  
  ]  
}
```

Bridge-emission alignment. The pre-existing CCPE-G-side ``recordBridgeEmission()`` recorder emits to the unified-audit ``[Audit] <type> <json>`` envelope from v0.7+ of RFC 0210 onward; the data-axis recorders specified here adopt the same envelope from initial publication.

13.A.6 Conformance Disposition

The default-shipped foundation is ``data-default`` until non-null adapters are registered against ``data_pdp`` and (where applicable) ``data_authority``. The per-instance ``conformanceDispositionHint`` field (``data-default`` / ``data-strict`` / ``data-behoerde``) drives the parameter-override selection at §3.1.1, §3.1.2, §6.1, §6.4, and §6.7 per the deployment's chosen profile (default vs. Strict vs. Behörde).

Reservation note. v0.7 reserves the lifecycle vocabulary ``deprecated`` and ``sunset_at`` for future slot-deprecation transitions, but does not prescribe transition mechanics; the formal lifecycle mechanics remain open at §13(s).

13.A.7 Dual-Path Architecture for Data-PDPs (Normative)

The Data-PDP slot model is the recommended path for vendor-managed substrates (Snowflake Horizon, Databricks Unity Catalog, Immuta SaaS, etc.) where per-vendor billing/commercial coupling justifies the slot lifecycle.

Self-hosted Policy-as-Code-style Data-PDPs May instead route through the PEP Phase-2 extension point per RFC 0150 §4.3.A precedent without slot registration. This dual path

is not a contradiction in the foundation contract — it reflects two distinct integration shapes:

- Slot-registered Data-PDPs carry a billable per-call meter (``recordDataDecision()``) and participate in cascades. They are first-class citizens of the registry.
- PaC-extension-point Data-PDPs are evaluated inline by the PEP and do not participate in registry-level metering or cascade. Self-hosted PaC customers do not pay per-call to Gimel for their own enforcement.

Choice criteria (Normative):

- A deployment Should select the slot-registered path when the Phase-2 back-end is operated by a commercial counterparty (vendor-managed SaaS or licensed enterprise software whose lifecycle the deployment does not control).
- A deployment Should select the PaC-extension-point path when the Phase-2 evaluator is a self-hosted policy engine (OPA, Cedar, Trino-with-rules, equivalent) whose lifecycle the deployment fully controls and whose evaluation does not couple to Gimel commercial metering.
- A deployment Must Not route the same Phase-2 evaluator through both paths simultaneously (would double-meter and would split cascade state).

Registration-time enforcement (Normative; promoted from Should to Must at v0.5). The reference operator's registry Must detect endpoint / URL collision between a slot-registered ``data_pdp`` instance and a PaC-extension-point Phase-2 evaluator at registration time and Must reject the second registration with a structured error code ``data_pdp_pac_extension_collision`` naming the previously-registered path. The detection scope is exact-match equivalence on the resolved Phase-2 endpoint URL (host, port, path) of the slot-registered adapter against the PaC-extension-point's registered evaluator address. Detection of semantic equivalence beyond exact-match (DNS aliases, CNAMEs, NAT-resolved alternatives, intermediate proxies) is undecidable in general and remains the deployment's operational responsibility; reference operators May offer additional opt-in equivalence checks but Must Not weaken the Must-level exact-match floor. This Must-level floor supersedes the v0.4 Should-level wording; deployments that already implemented the v0.4 Should-level detection require no code change.

(Operational guidance — Informative) The exact-match-on-resolved-endpoint floor is a robust normative anchor but is intentionally narrower than full semantic equivalence. The most likely false-negative pattern in deployment practice is shared-front-end topology: a slot-registered Data-PDP and a PaC-extension-point evaluator both routed through a shared reverse proxy, load balancer, ingress gateway, or service-mesh sidecar whose internal upstreams resolve to the same back-end host. Exact-match URL

comparison against the proxy-facing endpoint will not flag this configuration even though it is the dual-routing condition the §13.A.7 rule is intended to prevent. Reference operators Should treat shared-front-end topologies as a deployment-time review surface and Should document the resolved upstream of every Phase-2 endpoint in the deployment configuration so that human review can catch shared-back-end collisions that exact-match URL comparison would miss. Reference operators May offer an opt-in upstream-equivalence check that resolves Phase-2 endpoint URLs through configured proxy maps before comparison; such checks are additive to the Must-level floor and do not relax it.

This closes foundation-contract §10 item 13.

13.A.8 Reference Implementation

The reference realisation of §13.A lives in the GAuth Open-Core SDK at future versions (anchored normative dependency at §8.1) and in the Gimel Foundation reference operator (Gimel Auth) at the corresponding release. The realisation honours all of: §13.A.1 two-slot data-axis registry (composing into the canonical 13-slot registry surface alongside slots #1–#11 specified by other RFCs); §13.A.2 multi-instance ``data_pdp`` semantics with per-instance ``ccpe_h_scenario`` tagging; §13.A.3 single-instance ``data_authority`` with default-null adapter and duck-type guard; §13.A.4 four invariants on both recorders plus the open-core operator-mode guard; §13.A.5 audit-event wiring with bridge-emission alignment; §13.A.6 conformance-disposition hint; §13.A.7 dual-path architecture with Must-level collision detection and the v0.5.1 shared-front-end operational-guidance note.

From-scratch implementations of §13.A on alternative stacks (Go, Rust, Python; PostgreSQL or alternative storage) remain conformant if they honour §13.A.1–§13.A.7 and §6.5a.1–§6.5a.5 in full.

14. IANA / Registry Reservations (Normative)

This section reserves the identifiers introduced by §13.A and §6.5a and centralises the values that have until v0.3 been maintained inline across multiple recorders. These reservations are not sent to IANA — the GiFo registry is operated by the Gimel Foundation per RFC 0090 — but the IANA-style table format is adopted for editorial parity with sibling RFCs.

15.1 Tariff-Tier Identifiers

Identifier	Meaning	Customer-facing	Permitted setter
O	Open-core; <code>`operatorMode = user_self_hosted`</code> (default) or <code>`user_provided`</code> ; never billable	Yes	Any deployment operator
S	Standard; <code>`operatorMode = gimel_or_user`</code> ; billable per commercial schedule	Yes	Any deployment operator
M	Mid; <code>`operatorMode = gimel_or_user`</code> ; billable per commercial schedule	Yes	Any deployment operator
L	Large / enterprise; <code>`operatorMode = gimel_or_user`</code> ; billable per commercial schedule	Yes	Any deployment operator

Permitted-setter restriction (Normative; carried from v0.5). Tariff G is reserved for Foundation-internal-development operators only. The reference operator's registration validator Must reject any Tariff-G registration submitted by a non-Foundation operator with a structured error naming the §15.1 restriction. This closes a possible gaming vector where a non-Foundation operator could pin Tariff G in a deployment configuration to obtain the M-coerced lookup behaviour without operating under a Foundation-internal-development context.

Tier semantics (which tier costs what; which ``operatorMode`` is permitted at which tier under which contract) are governed by the Gimel Technologies open-core commercial schedule, not by this RFC (Two-Hats Footnote, §6.5a.5).

15.2 Slot-Type Identifiers and Operator-Mode Identifiers

Slot types. A = synchronous external system (Type-A; multi-instance candidate). B = asynchronous / longer-running external system (Type-B; single-instance default).

Operator modes (``operatorMode`` field on slot registrations):

- ``gimel_managed`` — Gimel operates the back-end on the deployment's behalf.
- ``user_provided`` — Deployment provisions and operates the back-end; routes through the Gimel-operated reference operator surface.
- ``user_self_hosted`` — Deployment fully self-hosts; never incurs a Foundation-side billable meter (§6.5a.2(2)).
- ``user_provided_required`` — Tariff-tier matrix vocabulary indicating that at this tariff the deployment Must provision its own back-end.
- ``null_or_user`` — Tariff-tier matrix vocabulary indicating that at this tariff the back-end May be null (default null) or deployment-provided.

- ``gimel_or_user`` — Tariff-tier matrix vocabulary indicating that at this tariff the deployment May use the Gimel-operated back-end or provision its own.

The full seven-value ``TariffSlotAvailability`` vocabulary used by the GAuth open-core implementation (``active_always`` / ``gimel_or_user`` / ``user_provided_required`` / ``null_or_user`` / ``attested_gimel`` / ``null_or_attested_gimel`` / ``null``) is documented descriptively at ``docs/CONNECTOR_SLOT_FOUNDATION.md` §5`; v0.7 reserves only the four values needed by the §13.A.1 matrix for ``data_pdp`` / ``data_authority``. The remaining values are GAuth-internal pending future review (tracked at §13(q)).

15.3 ``phase2_evaluation.profile`` — Central Registry

The ``phase2_evaluation.profile`` field is the unified-audit partitioning key originating in RFC 0140 v1.2 and Must appear on every CCPE-H audit event whose evaluation pertains to a single Data-PDP instance. Cascade-class events (``data.cascade.revoked``) that span multiple Data-PDPs Must instead carry ``phase2_evaluation.profiles[]`` per §13.A.5 — an array of `{ platform_id, profile }` mappings whose elements draw their profile value from the same reserved registry below. The two field shapes are mutually exclusive on a given event: a single-instance event carries the singular ``profile``, a multi-instance cascade event carries the plural ``profiles[]``, and a downstream consumer Must treat the absence of the singular field on a cascade event as the documented cascade shape, not as a missing partitioning key. Reserved values:

Profile Source Meaning

`ccpe-g RFC 0210 v0.7 Identity-axis profile (informative cross-reference)`

`ccpe-g-nci / ccpe-g-ncp / ccpe-g-nco RFC 0210 v0.7 §3.4 Identity-axis non-conformant variants (informative cross-reference)`

`*(`ccpe-g-ncm` reserved-but-not-listed; see footnote [†])*`
— —

`ccpe-f RFC 0170 v0.9.1 Commerce-axis profile (informative cross-reference)`

`ccpe-f-nci / ccpe-f-ncp / ccpe-f-nco RFC 0170 v0.9.1 §3.5 Commerce-axis non-conformant variants (informative cross-reference)`

`ccpe-h This RFC §4.5 G-Data conformant (S2 only per §4.5a)`

`ccpe-h-nci This RFC §4.6 No Credential-bound Integration`

ccpe-h-ncp Propagation	This RFC §4.6	No Cascade-revocation
ccpe-h-nco Preservation	This RFC §4.6	No Conformant-Order

Future ``data.*`` audit events introduced after v0.7 Must continue to use the ``data.*`` namespace.

[†] The value ``ccpe-g-ncm`` is not listed in the table above. RFC 0210 reserves only ``ccpe-g-nci`` / ``ccpe-g-ncp`` / ``ccpe-g-nco`` as identity-axis non-conformant variants. The ``ccpe-g-ncm`` identifier is held in reserve for re-addition when RFC 0210 v0.8+ publishes and Will be re-added to this table at the release that follows the RFC 0210 v0.8+ publication (gated at §13(x)). Until then a downstream consumer that encounters ``ccpe-g-ncm`` on the wire Must treat it as an unknown profile value per §15.3 reserved-registry semantics.

15.4 ``meteringLogCap`` Config Field

The per-recorder in-memory ring-buffer cap introduced at §6.5a.4 is reserved as a configuration field on every slot whose adapter participates in metering. Default value: 1 000 records per recorder. Permitted range: any non-negative integer. Operator-side persistent storage of metering aggregates is out of scope (§6.5a.4).

15.5 §7.x Cookbook-Section Identifier Shape

This subsection reserves the syntactic shape (not the content) of the ``cookbookSection`` field carried on §13.A.2 ``data_pdp`` registrations. The reservation gives registrations a stable normative anchor for the identifier shape while leaving the §7.x cookbook bodies themselves informative per §7's standing informative status and per the §13.A.2 layer clarification.

Permitted shapes (Normative):

- ``7.<n>.<slug>`` — references one of the §7.1–§7.9 substrate cookbooks; ``<n>`` ∈ {1, 2, 3, 4, 5, 6, 7, 8, 9} per the §7 substrate enumeration; ``<slug>`` is a deployment-supplied free-text token (e.g., ``7.6.immuta``, ``7.8.snowflake-horizon``).
- ``7.10:<extension-slug>`` — references the §7.10 cookbook extension hook for substrates not covered by §7.1–§7.9; ``<extension-slug>`` is a deployment-supplied free-text token (e.g., ``7.10:trino-pac``).

The reference operator's registration validator Should warn (not reject) on a ``cookbookSection`` value whose syntactic shape does not match either permitted form; rejection is reserved for future tightening if vendor adoption justifies it.

Appendix A. NIST AI RMF v1.0 — MAP Function Cross-Walk to CCPE-H (Informative — closed at v0.6, carried into v0.7)

This appendix gives the formal sub-category-to-CCPE-H-field cross-walk for the MAP function of NIST AI Risk Management Framework v1.0 (January 2023). The MAP function carries 18 sub-categories across five categories (MAP 1: Context is established and understood; MAP 2: Categorization of the AI system is performed; MAP 3: AI capabilities, targeted usage, goals, and expected benefits and costs are understood; MAP 4: Risks and benefits are mapped for all components including third-party software and data; MAP 5: Impacts to individuals, groups, communities, organizations, and society are characterized).

The table is informative. Each row names the MAP sub-category, the CCPE-H normative surface that addresses it (where applicable), and a short disposition note. Where a sub-category is an organizational-governance concern that the data-authorization profile cannot directly normatively close, the row carries an explicit "out-of-scope-with-indirect-support" disposition naming the CCPE-H artefact that supports the org-level activity even where the activity itself is out of scope.

Notational convention. CCPE-H surfaces are cited by section number (e.g., §3.1, §3.4, §13.A.6); audit-event types are cited as ``data.*`` per §3.4; obligation values are cited per §9.1. "OOS-IS" abbreviates "out-of-scope-with-indirect-support".

A.1 MAP 1 — Context is Established and Understood

MAP 1.1 (Intended purposes and deployment context documented).

CCPE-H normative surface: §3.1 ``purpose`` field (Data-Mandate envelope) — the per-action stated processing intent — together with §3.1.3 Purpose Vocabulary Registry, the Console-administered list of permitted purpose identifiers against which the Authority enforces registration-presence at issuance time. Audit anchor: ``data.purpose_attested`` (§3.4). Disposition: directly addressed.

MAP 1.2 (Inter-disciplinary AI actors / demographic diversity / domain expertise).

OOS-IS. The §2.4 three-service Console / Authority / Data-Runtime split provides the surface against which inter-disciplinary review happens (Console as the operator-facing review surface) but CCPE-H does not normatively constrain the actor mix or competency framework. Disposition: out-of-scope-with-indirect-support via §2.4 Console.

MAP 1.3 (Organization's mission and AI goals understood and documented).

OOS-IS. CCPE-H operationalizes mission-aligned purpose policy at the §3.1.3 Purpose Vocabulary Registry — the deployment controls which purposes are admissible — but the upstream mission articulation is org-level governance. Disposition: OOS-IS via §3.1.3.

MAP 1.4 (Business value or business context defined).

OOS-IS. The §3.1 `purpose` field captures per-action purpose articulation; aggregate business-value justification is org-level governance. Disposition: OOS-IS via §3.1 `purpose`.

MAP 1.5 (Organizational risk tolerances determined and documented).

CCPE-H normative surface: §13.A.6 conformance-disposition hint (`data-default` / `data-strict` / `data-behoerde`) selects the parameter-override profile (§3.1.1 parent-mandate-state staleness ceiling; §3.1.2 phase2_timeout_ms; §6.4 key rotation; §6.7 replay-defence skew window) corresponding to the deployment's chosen risk-tolerance posture. Disposition: directly addressed via §13.A.6 + §3.1.1 / §3.1.2 / §6.4 / §6.7.

MAP 1.6 (System requirements elicited from and understood by AI actors).

CCPE-H normative surface: §3.1 `data\_constraints` carrier — `tenant\_egress\_boundary`, `retention\_ceiling`, `no\_retraining` — which are the CCPE-H mechanism for translating system requirements ("respect privacy"; "do not export outside tenant"; "do not retrain") into per-mandate enforceable constraints. Obligation anchors: `egress\_outside\_tenant\_denied`, `no\_retraining\_required` (§9.1). Disposition: directly addressed.

A.2 MAP 2 — Categorization of the AI System

MAP 2.1 (Tasks and methods used to implement the tasks defined).

CCPE-H normative surface: §3.1 `operations` field (subset of {read, aggregate, derive, write, egress, train}) — the operations enumeration is the CCPE-H operationalization of "what specific data tasks does this AI system perform." Audit anchors: `data.action\_proposed`, `data.action\_decided` (§3.4). Disposition: directly addressed.

MAP 2.2 (Knowledge limits and human oversight of system output documented).

CCPE-H normative surface: §3.3 ``obligations`` array under the ``constrain`` verdict — when the chain returns ``constrain``, the ``obligations`` array carries constraint instructions back to the agent describing the narrowed envelope under which the action is permitted. §13.A.6 Strict / Behörde profile-disposition hints raise the oversight bar. §2.4 Console is the human-oversight surface. Disposition: directly addressed via §3.3 + §13.A.6 + §2.4.

MAP 2.3 (Scientific integrity and TEVV considerations identified).

OOS-IS. CCPE-H provides the §3.5 lineage-attestation event as the substrate against which TEVV (Test, Evaluation, Verification, Validation) of model behaviour can be evidenced after the fact, but does not specify the TEVV methodology itself. Disposition: OOS-IS via §3.5.

A.3 MAP 3 — Capabilities, Targeted Usage, Goals, Benefits and Costs

MAP 3.1 (Potential benefits documented).

OOS-IS. The §3.1 ``purpose`` field captures per-action benefit framing; aggregate benefits analysis is org-level governance. Disposition: OOS-IS via §3.1 ``purpose``.

MAP 3.2 (Potential costs / AI errors / system functionality and trustworthiness).

CCPE-H normative surface: §6.5a per-call metering (``recordDataDecision()``) provides the per-decision cost ledger; §3.4 audit events provide error and failure visibility (``data.platform_bound.failure`` carrying ``phase2_unreachable``; ``data.action_decided`` with ``verdict = deny`` and the diagnostic obligation codes from §9.1 — ``parent_chain_invalid``, ``mandate_already_consumed``, ``phase2_unreachable``). Aggregate cost analysis is org-level. Disposition: directly addressed for the per-decision ledger surface; OOS-IS for aggregate analysis.

MAP 3.3 (Targeted application scope specified).

CCPE-H normative surface: §3.1 ``dataset_scope`` field — the Data-Mandate envelope normatively carries the dataset scope; the §3.2 scope-narrowing invariant ensures descendant mandates can only narrow, not widen, the scope. Disposition: directly addressed.

MAP 3.4 (Operator and practitioner proficiency / standards / certifications).

OOS-IS. CCPE-H provides §13.A.6 conformance-disposition hints as the mechanism by which deployments can claim Strict / Behörde profile conformance (the closest surface for standards-claim operationalization); the v1.0 Strict / Behörde profile bodies are tracked at §13(f). Disposition: OOS-IS via §13.A.6 (deepens to "directly addressed" once §13(f) closes).

MAP 3.5 (Human oversight processes defined, assessed, documented).

CCPE-H normative surface: §2.4 three-service split with Console as operator-facing surface for human review; §3.3 `constrain` verdict pattern (mandate is permitted in narrowed form, requires human-supervised constraint compliance); §13.A.6 Strict / Behörde profile bodies. Disposition: directly addressed via §2.4 + §3.3 + §13.A.6.

A.4 MAP 4 — Risks and Benefits Mapped Across Components

MAP 4.1 (Approaches for mapping AI tech and legal risks of components, including third-party data or software).

CCPE-H normative surface: §3.1 `data\_constraints.tenant\_egress\_boundary` (egress outside tenant denied — the principal mechanism for legal-risk containment of third-party data egress); §7 cookbook bodies (substrate-side integration for catalogue / overlay / platform-native data sources); §3.5 lineage-attestation (third-party data lineage captured at every aggregate / derive / write / egress / train). Obligation anchor: `egress\_outside\_tenant\_denied` (§9.1). Disposition: directly addressed for the data-axis third-party-component surface.

MAP 4.2 (Internal risk controls for components, including third-party AI technologies).

CCPE-H normative surface: §3.1 `data\_constraints.no\_retraining` (prevents third-party model training on tenant data — the principal mechanism for AI-tech component risk control on the data-axis); §13.A multi-instance Data-PDP slot model (per-substrate enforcement boundary; cross-substrate risk segmentation). Audit anchor: `data.lineage\_recorded` with `operations` containing `train` is the auditable evidence of any training event against the mandate. Obligation anchor: `no\_retraining\_required` (§9.1). Disposition: directly addressed.

A.5 MAP 5 — Impacts to Individuals, Groups, Communities, Organizations, Society

MAP 5.1 (Likelihood and magnitude of identified impacts).

CCPE-H normative surface: §6.5a per-call metering provides the quantitative basis for likelihood (call volume ledger; `MeteringResult` records bounded by §6.5a.4 `meteringLogCap`); §3.4 audit trail provides the historical incident corpus (deny / constrain decisions; `data.platform\_bound.failure` events). Magnitude analysis (impact severity calibration) is org-level. Disposition: directly addressed for the likelihood surface; OOS-IS for the magnitude surface.

MAP 5.2 (Stakeholder engagement and feedback integration).

OOS-IS. §3.4 audit trail and §3.5 lineage-attestation provide the substrate against which stakeholder feedback can be evidenced (auditors and stakeholders can trace decisions and attestations) but the engagement framework itself is org-level. Disposition: OOS-IS via §3.4 + §3.5.

A.6 Coverage Summary

Of the 18 NIST AI RMF v1.0 MAP sub-categories cross-walked above, 11 are directly addressed by a CCPE-H normative surface (MAP 1.1, 1.5, 1.6, 2.1, 2.2, 3.2 partial, 3.3, 3.5, 4.1, 4.2, 5.1 partial), and 7 carry an out-of-scope-with-indirect-support disposition (MAP 1.2, 1.3, 1.4, 2.3, 3.1, 3.4, 5.2; with MAP 3.2 and MAP 5.1 partial-OOS-IS for their aggregate/magnitude sub-surfaces). The 7 OOS-IS dispositions reflect the boundary between data-authorization (CCPE-H's normative scope) and organizational-governance (the GOVERN function of NIST AI RMF, which CCPE-H does not address); each OOS-IS row names the CCPE-H artefact that supports the org-level activity even where the activity itself is org-side.

A.7 Forward Cross-Walks (Open at §13(y))

Companion appendices for the NIST AI RMF MEASURE, MANAGE, and GOVERN functions are tracked at §13(y) for sequencing across v0.8 / v0.9 / v0.10. The MEASURE cross-walk is the natural next priority because the §3.4 audit trail and §3.5 lineage-attestation are already-built substrates that downstream MEASURE-class evaluation can consume directly without further normative work.

Disclaimer: ALL DOCUMENTS AND THE INFORMATION CONTAINED THEREIN ARE PROVIDED ON AN “AS IS” BASIS AND THE CONTRIBUTOR, THE ORGANIZATION THEY REPRESENT OR ARE SPONSORED BY (IF ANY), THE GIMEL FOUNDATION, AND ANY APPLICABLE MANAGERS OF ALTERNATE DOCUMENT STREAMS, DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO ANY WARRANTY THAT THE USE OF THE INFORMATION THEREIN WILL NOT INFRINGE ANY RIGHTS OR ANY IMPLIED WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE.

PRODUCT NAMES, TRADEMARKS, AND REGISTERED TRADEMARKS REFERENCED IN THIS DOCUMENT ARE THE PROPERTY OF THEIR RESPECTIVE OWNERS AND ARE USED FOR IDENTIFICATION PURPOSES ONLY. NO ENDORSEMENT IS IMPLIED.

* * *